СКУТУМ

Платформа за управљање информационом безбедношћу и дигиталним поверењем

Пројектна спецификација за предмет Основе информационе безбедности
Факултет техничких наука - Примењено софтверско инжењерство

Основни подаци

Табела 1. Ставка и Вредност

Ставка	Вредност
Назив пројекта	**СКУТУМ - Платформа за управљање информационом безбедношћу и дигиталним поверењем**
Предмет	Основе информационе безбедности
Тип рада	Тимски развој заједничког безбедносног софтверског производа
Величина тима	6-10 студената
Број пројектних целина	90 (30 на нивоу P1, 30 на нивоу P2 и 30 на нивоу P3)
Типичан обим извођења	приближно 200 студената; број тимова зависи од формиране величине тимова
Референтна технологија	дотнет / Ц шарп; друге технологије уз одобрење и доказ интероперабилности
Организација рада	Гит, развојне гране, Захтев за спајање измена, преглед кода, Континуирана интеграција и Тапиз табле
Архитектонски принципи	Чиста архитектура, СОЛИД, леаст привилеге, експлицит труст боундариес, тестабилност и аудитабилност

Нормативне конвенције и следљивост

Спецификација користи следећа нормативна значења како би се смањила могућност различитог тумачења захтева:

- **мора / није дозвољено** - обавезан захтев; неиспуњење значи да захтев није реализован;
- **треба / очекује се** - подразумевано очекивање које може бити одступање само уз образложену и документовану одлуку;
- **може / могуће проширење** - опционо; није део минималног обухвата осим ако га наставни тим експлицитно додели;
- **обавезни случај употребе** - понашање које мора бити демонстрабилно и покривено одговарајућим тестовима;
- **кључна пословна / безбедносна правила** - invariants/ograničenja која имплементација мора сачувати независно од УИ-а и техничког решења.

Следљивост захтева

- ознака пројектне целине, нпр. `R2-05`, представља стабилан идентификатор њеног функционалног и безбедносног обухвата;
- захтеви у Тапиз-у, тестовима, Записи о архитектонским одлукама записима и Захтев за спајање измена описима треба да референцирају ознаку целине и конкретан случај употребе или безбедносно правило;
- за међутимски и системске захтеве користе се експлицитни идентификатори облика `SEC-<oblast>-NN`, наведени у овој спецификацији;
- једном објављен идентификатор се не користи за друго значење; промена семантике захтева евидентира се кроз контролисану ревизију спецификације;

- некомпатибилна промена јавног уговора, сецурити догађаја или полици семантике мора имати следљив Тапиз задатак, преглед погођених тимова и ажуриране contract/security тестове.

1 Сврха, циљ и границе пројекта

СКУТУМ је информациони систем намењен управљању идентитетима, приступом, безбедносним политикама, тајнама, безбедносним догађајима, инцидентима, ризицима и доказима у организацији која користи већи број апликација, сервиса и информационих ресурса. Безбедност није додатна функционалност система, већ основни домен пројекта.

Пројекат је дефанзивно оријентисан. Не захтева развој експлоита, малвера нити напад на реалне системе. Ситуације које представљају сумњиву активност, грешку конфигурације или покушај недозвољеног приступа репродукују се контролисаним симулаторима и тестним идентитетима.

Циљ пројектног оквира. Студент треба да разуме везу између ассет-а, идентитета, труст границе, претње, контроле, безбедносног теста и аудит доказа. Имплементација контроле без јасног безбедносног захтева и теста не сматра се завршеним решењем.

1.1 Обухват

- идентити лифецицле, аутентикација и сесије;
- Контрола приступа заснована на улогама, објецт-левел и полици-басед ауторизација;
- мулти-фацтор и степ-уп аутентикација;
- привилегед аццесс и јуст-ин-тиме права;
- сервице идентитиес;
- сецретс, цертификате и кеи лифецицле;
- класификација података и заштита ресурса;
- сецурити аудит, догађаји, детекција и алертинг;
- сецурити инцидент, истрага, евиденце и респонсе;
- вулнерабилити и депенденци риск регистри;
- моделовање претњи, риск манагемент и аццесс преглед;
- сецурити полициес, ексцептионс и цомплианце евиденце;
- аутоматизовани негативни и безбедносни тестови.

1.2 Ван обухвата

- напад на стварне организационе или јавне системе;
- израда малваре-а, рансомваре-а, пхисхинг инфраструктуре или експлоита;
- имплементација сопствених криптографских алгоритама;
- чување реалних лозинки, тајни или продукционих сертификата у студентском окружењу;
- представљање симулатора као реалног IDS/SIEM/CA производа;
- формална pravna/compliance сертификација организације.

Пример 1

```
flowchart LR
    U[Employee / User] --> S((SCUTUM))
    A[Security Administrator] --> S
    SO[Security Operator] --> S
    AU[Auditor] --> S
    IO[Incident Responder] --> S
    OW[Resource Owner] --> S

    S <--> IDP[Identity Provider Simulator]
    S <--> OTP[OTP / MFA Simulator]
    S <--> CA[Certificate Authority Simulator]
    S <--> EXT[External Application Simulator]
    S <--> TH[Threat Event Simulator]
    S <--> VS[Vulnerability Scanner Simulator]
```

Слика 1. Контекст система СКУТУМ: корисници и спољни безбедносни симулатори.

2 Контекст система и корисници

СКУТУМ се посматра као централна безбедносна платформа која одржава идентитете, политике, ассет податке и безбедносне догађаје за више апликација и организационих домена. Спољни системи комуницирају преко експлицитних адаптера или симулатора.

2.1 Примарне улоге

Табела 2. Улоīа и Типичне одīоворноси

Улога	Типичне одговорности
Емплоиее / Усер	користи заштићене ресурсе у оквиру додељених права
Ресоурце Овнер	одређује власништво, класификацију и одобрава одређене приступе
Сецурити Администратор	политике, identity/security конфигурација и привилеговане промене
Сецурити Оператор / Аналист	сецурити евентс, алертс, триаге и надзор
Инцидент Респондер	истрага, цонтаинмент, рецовери и пост-инцидент преглед
Аудитор / Реад-онли Оператор	контролисан преглед аудит-а, евиденце-а и цомплианце доказа

2.2 Труст границе

За сваки значајан ток мора бити јасно где се идентитет потврђује, где се доноси одлука о приступу, ко је власник заштићеног ресурса и које информације прелазе границу између компоненти.

Пример 2

```
flowchart TB
    U[User / Service Identity] --> AUTH[Authentication]
    AUTH --> CTX[Context + Session]
    CTX --> AUTHZ[Authorization / Policy Decision]
    R[Protected Resource] --> AUTHZ
    CLASS[Data Classification] --> AUTHZ
    AUTHZ -->|allow| ACCESS[Controlled Access]
    AUTHZ -->|deny| DENY[Access Denied]
    ACCESS --> AUDIT[Audit / Security Event]
    DENY --> AUDIT
```

Слика 2. Поједностављен модел доношења одлуке о ūристуūу.

2.3 Симулатори

Табела 3. Симулатор и Пример ūонашања

Симулатор	Пример понашања
Идентити Провидер Симулатор	uspešna/neuspešna аутентикација, екстернал идентити
ОТП / Вишефакторска аутентикација Симулатор	цхалленге, validan/nevalidan код, истек времена
Цертификате Аутхорити Симулатор	издавање, обнова и ревоцатион сертификата
Екстернал Апплицатион Симулатор	позиви ка заштићеном Програмски интерфејс-ју и сервице идентити сценарио
Тхреат Евент Симулатор	неуспешне пријаве, суспициоус аццесс, привилегована операција
Вулнерабилити Сканнер Симулатор	контролисани налази везани за тестне ассет-е

3 Безбедносни модел система

СКУТУМ не полази од претпоставке да је корисник, сервис или мрежна локација поуздана само зато што је успешно прошла један претходни корак. Свака значајна операција мора имати јасан идентитет, обухват и одлуку о приступу.

3.1 Основна правила

- леаст привилеге и неед-то-кнов где су релевантни;
- дени-би-дефаулт за осетљиве операције где није експлицитно дозвољено;
- аутентикација и ауторизација су одвојене одговорности;
- валидан токен не значи аутоматски приступ сваком ресурсу;
- објецт-левел аутхоризатион проверава се серверски;
- привилеговани приступ треба да буде ограничен обухват-ом и временом;
- тајне се не чувају у соурце цоде-у или логовима;
- стандардне проверене криптографске библиотеке се користе уместо сопствених алгоритама;
- безбедносна одлука мора бити проверљива тестом и аудит догађајем где је значајно.

3.2 Безбедносни ток као доказ

Свака пројектна целина треба да може да покаже следећи ланац када је применљив:

Пример 3

```
Asset -> Threat / Misuse -> Security Requirement -> Control -> Security Test -> Evidence
```

Пример 4

```
flowchart TB
    R1[R1 - osnovni nivo<br/>identitet, resursi, klasifikacija,<br/>autorizacija, audit]
--> R2[R2 - operativni nivo<br/>MFA, sessions, secrets, detection,<br/>incidents,
vulnerabilities]
    R2 --> R3[R3 - napredni nivo<br/>policy engine, access review, risk,<br/>correlation,
response automation]
```

Слика 3. Развојни нивои пројектних целина; ознаке представљају функционалне предуслове.

4 Развојни нивои и додела пројектних целина

Ознаке P1, P2 и P3 представљају функционалне предуслове и зрелост пројектне целине. Не представљају академску годину и не дају студентима право да самостално изаберу тему. Целине додељује наставни тим.

Табела 4. Ниво и Значење

Ниво	Значење	Типични садржај
P1 - Основни	поставља ассет, идентити, аутхоризатион, полици и аудит темеље	идентитети, ресурси, Контрола приступа заснована на улогама, класификација, аудит, баселине
P2 - Оперативни	уводи активне заштитне и оперативне безбедносне процесе	Вишефакторска аутентикација, сессионс, сецретс, детецтион, инцидентс, вулнерабилитиес
P3 - Напредни	уводи сложеније полици, риск и респонсе токове	ABAC/policy енгине, аццесс преглед, риск, цоррелатион, респонсе аутоматион

Додела пројектних целина. Тим може развијати нову целину, проширивати постојећу или безбедносно рефакторисати постојеће решење. Наставни тим може раније активирати R2/R3 целину ако су њени предуслови доступни или контролисано симулирани.

4.1 Тимови

Тим има 6-10 студената. Једна пројектна целина представља примарну одговорност тима, а велика целина може се поделити на јасно раздвојене епике ако број тимова то захтева.

Сваки тим треба да демонстрира комбинацију:

- нове или измењене функционалности;
- најмање једног negativnog/abuse сценарија;
- аутоматизованог безбедносног теста;
- најмање једне међутимски труст границе када је домен то захтева; када тим сматра да значајна интеграција није применљива, разлог мора бити експлицитно потврђен са наставним тимом;
- тхреат модел-а своје целине;
- рефакторисања ако постојећи дизајн онемогућава безбедну имплементацију.

5 Општи технички и процесни захтеви

5.1 Технолошки оквир

Подразумевана и препоручена технологија је дотнет / Ц шарп. Друга технологија може бити одобрена када тим обезбеди интероперабилност и еквивалентан ниво тестирања и безбедносне контроле.

5.2 Архитектура и безбедан дизајн

- Чиста архитектура или еквивалентно јасно раздвајање домена, случај употребе слоја и инфраструктуре;
- СОЛИД тамо где смањује спрегнутост и олакшава тестирање;
- auth/authz, сецретс и аудит не смеју бити разбацани ад-хоц кроз код;
- значајне труст границе морају бити експлицитне;
- безбедносно критичне одлуке документују се кратким Записи о архитектонским одлукама записом;
- сопствени сгурто/password/token алгоритми нису дозвољени;
- хард-цодед цредентиал-и и тајне нису прихватљиви.

5.3 Тхреат модел по тиму

Минимални тхреат модел мора садржати:

Табела 5. Елемент и Пример

Елемент	Пример
Ассет	корисничка сесија, тајна, документ, привилегована улога
Тхреат / мисусе	крађа сесије, хоризонтални приступ, неовлашћена промена привилегије
Цонтрол	степ-уп, објецт аутхоризатион, ревоцатион, аудит
Тест	негативни аутхоризатион тест, expired/revoked цредентиал тест
Евиденце	резултат теста, аудит догађај, конфигурациони доказ

5.4 Тестирање

Фрамеворк зависи од технологије: NUnit/Moq за дотнет, Vitest/Jest за TypeScript или еквивалентан алат.

- унит тестови полици и пословних правила;
- интегратион тестови authentication/authorization адаптера;
- објецт-левел негативе тестови;
- тестови isteka/revocation-a;
- тестови tenant/scope изолације где постоји;
- тестови сецурити event/audit исхода;
- регрессион тест за стварно откривен безбедносни проблем када је могуће.

5.5 Гит, Захтев за спајање измена и Тапиз табле

Пример 5

```
Tapiz task -> feature branch -> commits -> Pull Request -> CI + review -> VERIFY / SECURITY QA -> DONE
```

- директан слање измена на главна грана није дозвољен;
- сецурити рекуиремент и аццептанце критеријуми морају бити видљиви у задатак-у;
- промена auth/authz уговора захтева преглед погођених тимова;
- Континуирана интеграција извршава изградња, тестове и релевантне сецурити цхецкс;
- тајне не смеју бити комит-ован у репозиторијум.

5.6 Дефиниција завршености

- функционални аццептанце критеријуми су испуњени;
- threat/misuse сценарио је дефинисан;
- контрола је имплементирана и објашњива;
- најмање један негативни сецурити сценарио је тестиран;
- audit/security евент постоји где је релевантно;
- тајне и осетљиви подаци нису изложени;
- Континуирана интеграција пролази;
- ПР је прегледан;
- документација, јавни уговори и Записи о архитектонским одлукама су ажурирани;
- аццептед међутимски уговор, сецурити евент или полици граница имају овнер-а, цонсумер-е и одговарајући contract/security тест;
- локално окружење, миграције и seed/demo подаци могу се поновљиво покренути по документованом поступку;
- tenant/scope-aware целина има најмање један негативни аутоматизовани тест који покушава недозвољен приступ туђем ресурсу;
- тим може објаснити ресидуал риск или познато ограничење.

5.7 Заједничке техничке и безбедносне конвенције

Следећа правила важе на границама између пројектних целина. Она не прописују конкретан фрамеворк, базу или транспортни протокол, већ заједнички језик који смањује случајне интеграционе и безбедносне пропусте.

- `SEC-CONV-01` - идентификатори изложени преко јавног уговора морају имати документован тип, формат и правило јединствености; цонсумер не сме зависити од интерног начина генерисања ИД-а;
- `SEC-CONV-02` - идентитет субјекта, tenant/security домен, обухват и ассуранце левел морају бити експлицитни у апликационом контексту сваке сецурити одлуке;
- `SEC-CONV-03` - очекивани безбедносни неуспех мора имати стабилан машински препознатљив kod/vrstu и читљиву поруку; цонсумер не сме парсирати произвољан текст грешке;
- `SEC-CONV-04` - сецурити евент мора имати минимално: време, actor/service идентити, акцију, таргет, исход, корелациони идентификатор и класификацију осетљивости;
- `SEC-CONV-05` - тајне, токени и цредентиал вредности никада нису део јавног ДТО-а, лога, аудит детаља или демо сеед-а;
- `SEC-CONV-06` - колекциони API/ugovori који могу расти морају дефинисати ограничење величине одговора и, где је релевантно, pagination/filter семантику;
- `SEC-CONV-07` - некомпатибилна промена јавног DTO/event/contract модела захтева нову компатибилну верзију, миграциони период или координисану промену свих активних цонсумер-а;
- `SEC-CONV-08` - операције које могу бити безбедно поновљене треба да имају дефинисану идемпотенци семантику; дуплирана порука не сме неконтролисано дуплирати сецурити ефекат;
- `SEC-CONV-09` - конкурентне измене привилегија, полици-ја, тајни или инцидент статуса морају имати дефинисану стратегију конфликта;

- SEC-CONV-10 - власник пројектне целине управља својим персистенце моделом и миграцијама; друга целина не мења његове табеле без договорене међутимски промене.

5.8 Животни циклус јавних уговора и сецурити догађаја

Јавни уговор је Програмски интерфејс, event/message сцхема, полици децисион формат, евиденце формат или други формални облик комуникације који користи друга пројектна целина.

Пример 6

```
DRAFT -> ACCEPTED -> DEPRECATED -> RETIRED
```

- SEC-CONTRACT-01 - сваки јавни уговор има јасно наведеног овнер-а и познате цонсумер-е;
- SEC-CONTRACT-02 - стање DRAFT може да се мења без компатибилности само док га ниједан други тим не користи као прихваћену границу;
- SEC-CONTRACT-03 - прелазак у ACCEPTED захтева најмање један репрезентативан contract/security тест или други извршив доказ договорене семантике;
- SEC-CONTRACT-04 - некомпатибилна промена ACCEPTED уговора захтева координацију са погођеним цонсумер-има пре мерге-а;
- SEC-CONTRACT-05 - DEPRECATED уговор остаје подржан током договореног миграционог периода; разлог и замена морају бити документовани;
- SEC-CONTRACT-06 - RETIRED уговор се уклања тек када нема активних цонсумер-а или када је наставни тим експлицитно одобрио координисано уклањање.

5.9 Рад са недоступним предусловима

Пројектна целина вишег нивоа може почети пре пуне имплементације предуслова само ако је граница контролисано симулирана.

- SEC-DEP-01 - овнер зависне целине документује минимални цонтрацт који очекује од недоступног предуслова;
- SEC-DEP-02 - simulator/stub мора подржати најмање нормалан исход и релевантне negativne/failure исходе потребне за развој;
- SEC-DEP-03 - симулатор не сме садржати сецурити логику која припада упстреам целини; он само репродукује договорено спољашње понашање;
- SEC-DEP-04 - када стварна имплементација постане доступна, исти contract/security тестови треба да могу да се изврше над стварним адаптером или одговарајућим интеграционим окружењем;
- SEC-DEP-05 - разлика између симулатора и стварне имплементације третира се као интеграциони проблем и мора бити решена пре затварања зависне целине.

5.10 Безбедносни аццептанце баселине

- SEC-BASE-01 - аутхоризатион се проверава serverski/aplikaciono на свакој операцији која мења или чита заштићен ресурс;
- SEC-BASE-02 - tenant/scope-aware целина мора имати аутоматизован негативни тест који доказује да корисник једног обухвата не може приступити ресурсу другог обухвата само познавањем идентификатора;
- SEC-BASE-03 - привилеговане и административне промене морају произвести audit/security евент са идентитетом извршиоца и релевантним контекстом;
- SEC-BASE-04 - тајне, токени и креденцијали не смеју бити комит-овани у репозиторијум нити хард-цодед у изворни код;
- SEC-BASE-05 - улази који утичу на сецурити одлуке, персистенце или аудит морају бити валидирани на одговарајућој апликационој граници;
- SEC-BASE-06 - одговор према цонсумер-у не сме излагати интерне податке другог сецурити домена или техничке детаље који нису део јавног уговора;
- SEC-BASE-07 - стварни напад, експлоит, пхисхинг инфраструктура, малваре или рад над реалним спољним системом нису део пројекта.

5.11 Оперативни и НФР баселине

Ови захтеви нису индустријски SOC/SIEM бенцхмарк; циљ је да заједнички студентски производ буде поновљив, дијагностикабилан и одржив.

- `SEC-OPS-01` - цлеан цлоне репозиторијума мора моћи да се изградња-ује и покрене по документованом поступку без ручних корака познатих само једном члану тима;
- `SEC-OPS-02` - миграције морају моћи да формирају потребну шему над празном базом или другим чистим персистенце окружењем;
- `SEC-OPS-03` - seed/demo подаци морају омогућити поновљив приказ нормалног и негативног безбедносног сценарија;
- `SEC-OPS-04` - апликација и адаптери морају емитовати довољно структурисаних лог информација да се може пратити неуспешан сецурити ток без дебуггер-а на рачунару аутора;
- `SEC-OPS-05` - екстерни позиви морају имати разумно понашање при timeout-u/nedostupnosti; отказ спољног симулатора не сме произвести неконтролисано неконзистентно сецурити стање;
- `SEC-OPS-06` - конфигурација окружења мора бити одвојена од кода и без тајни у репозиторијуму;
- `SEC-OPS-07` - Континуирана интеграција мора проверити изградња, тестове и статичке провере на начин који не зависи од локалног ИДЕ окружења.

6 Кључни безбедносни токови и тхреат модел

6.1 Приступ заштићеном ресурсу

Аутентикован корисник не добија аутоматски право приступа конкретном објекту. Одлука мора узети у обзир ownership/scope, активну политику и евентуални степ-уп захтев.

Пример 7

```
flowchart TB
    U[Authenticated User] --> REQ[Request Protected Resource] --> DEC[Authorization
Decision]
    OWN[Ownership / Scope] --> DEC
    POL[Active Policy] --> DEC
    STEP[Step-up Status] --> DEC
    DEC -->|allow| ALLOW[Access Granted]
    DEC -->|deny| DENY[403 Access Denied]
    ALLOW --> EVT[Security Event / Audit]
    DENY --> EVT
```

Слика 4. Референтни ток приступа заштићеном ресурсу.

6.2 Привилеговани приступ

Привилегована права представљају посебан ризик и треба да буду експлицитно захтевана, одобрена, додатно потврђена и временски ограничена.

Пример 8

```
stateDiagram-v2
    [*] --> Requested
    Requested --> Rejected
    Requested --> Approved
    Approved --> StepUpRequired
    StepUpRequired --> Active
    Active --> Expired
    Active --> Revoked
    Approved --> Revoked
    Rejected --> [*]
    Expired --> [*]
    Revoked --> [*]
```

Слика 5. Поједностављен животни циклус привилегованог приступа.

6.3 Безбедносни догађај и инцидент

Пример 9

```
flowchart TB
    E[Security Event] --> D[Detection Rule] --> A[Alert] --> T[Triage] --> I[Security
Incident]
    I --> INV[Investigation / Evidence] --> C[Containment]
    C --> R[Recovery / Post-Incident Review]
```

Слика 6. Веза безбедносног догађаја, детекције, инцидента и опоравка.

6.4 Тајна или сервисни креденцијал

Пример 10

```
stateDiagram-v2
    [*] --> Created
    Created --> Active
    Active --> Rotating
    Rotating --> Active
    Active --> Revoked
    Active --> Expired
    Expired --> Rotating
    Revoked --> [*]
```

Слика 7. Поједностављен животни циклус тајне или приступног креденцијала.

6.5 Тхреат -> Цонтрол -> Евиденце

Пример 11

```
flowchart TB
    AS[Asset] --> TH[Threat] --> V[Vulnerability / Weakness] --> R[Risk]
    R --> C[Security Control] --> T[Security Test] --> E[Evidence / Residual Risk Review]
```

Слика 8. Веза ассет-а, претње, контроле, теста и доказа.

6.6 Сервице-то-сервице труст

Пример 12

```
flowchart TB
    S1[Service A] --> ID1[Service Identity]
    S2[Service B] --> ID2[Service Identity]
    ID1 --> POL[Trust / Authorization Policy]
    ID2 --> POL
    POL --> SEC[Protected API / Secret / Certificate]
    SEC --> AUD[Audit + Security Telemetry]
```

Слика 9. Концептуална граница поверења између сервисних идентитета.

Напомена. Пројекат је дефанзивно оријентисан. Негативни и абусе сценарији изводе се над сопственим тестним системом и симулаторима, без напада на реалне спољне системе.

Преглед пројектних целина

Табела 6. Ознака и Пројектна целина

Ознака	Пројектна целина	Ниво	Главни предуслови
P1-01	Организације, безбедносни домени и власништво	P1	нема обавезних
P1-02	Ассет инвентори и критичност ресурса	P1	P1-01
P1-03	Идентити регистри и животни циклус корисника	P1	нема обавезних
P1-04	Основна аутентикација	P1	P1-03

Ознака	Пројектна целина	Ниво	Главни предуслови
P1-05	Улоге и основни Контрола приступа заснована на улогама	P1	P1-03
P1-06	Објецт-левел аутхоризатион и власништво ресурса	P1	P1-05, P1-02
P1-07	Класификација података и правила руковања	P1	P1-02
P1-08	Сецурити полици каталог	P1	P1-01
P1-09	Аудит лог и безбедносни догађаји	P1	P1-03, P1-05
P1-10	Сецуре цонфигуратион баселине	P1	P1-02, P1-08
P1-11	Сецурити нотификатионс и одговорни контакти	P1	P1-01, P1-09
P1-12	Сецурити симулатори и тест идентитиес	P1	нема обавезних
P1-13	Безбедносна могућност посматрања система основа	P1	P1-09
P1-14	Сецурити зоне и труст-боундари регистри	P1	P1-01, P1-02
P1-15	Дата ретентион и сецуре диспосал полици	P1	P1-07, P1-08
P1-16	Каталог безбедносних контрола и власништво	P1	P1-01, P1-08
P1-17	Цриптографхиц ассет инвентори	P1	P1-01, P1-02, P1-08
P1-18	Екстернал експосуре и аттацк-сурфаце регистри	P1	P1-02, P1-14
P1-19	Сецурити дата-соурце и лог-соурце регистри	P1	P1-09, P1-13
P1-20	Дата-флов и процессинг регистри	P1	P1-07, P1-14, P1-02
P1-21	Цонсент и лавфул-басис регистри	P1	P1-07, P1-20
P1-22	Сецурити траининг и аваренесс регистри	P1	P1-01, P1-03
P1-23	Ексцептион и полици ваивер цаталог	P1	P1-08, P1-16
P1-24	Machine/service аццоунт овнерсхип регистри	P1	P1-02, P1-03, P1-05
P1-25	Токен, сессион и цредентиал метадата регистри	P1	P1-04, P1-09
P1-26	Крајња тачка и девице инвентори труст атрибути	P1	P1-02, P1-14
P1-27	Евиденце репозиторијум и цхаин-оф-цустоди основа	P1	P1-09, P1-16
P1-28	Сецурити плаибоок каталог	P1	P1-11, P1-16
P1-29	Бусинесс импацт и цровн-јевел маппинг	P1	P1-01, P1-02, P1-07
P1-30	Цонтрол овнерсхип и респонсибилити матрикс	P1	P1-01, P1-08, P1-16
P2-01	Мулти-фацтор и степ-уп аутентикација	P2	P1-04, P1-12
P2-02	Сессионс, токенс и ревоцатион	P2	P1-04, P1-09
P2-03	Привилегед Аццесс и Јуст-ин-Тиме приступ	P2	P1-05, P2-01
P2-04	Сервице идентитиес и радно оптерећење аутхентицатион	P2	P1-02, P1-08
P2-05	Сецретс манагемент и лифецицле	P2	P2-04, P1-09
P2-06	Цертификатес и кеи лифецицле	P2	P1-12, P2-04
P2-07	Сецурити детецтион рулес	P2	P1-09, P1-12
P2-08	Сецурити алертс и триаге	P2	P2-07, P1-11
P2-09	Сецурити инцидент манагемент	P2	P2-08, P1-02
P2-10	Инвестигатион, евиденце и тимелине	P2	P2-09, P1-09

Ознака	Пројектна целина	Ниво	Главни предуслови
P2-11	Вулнерабилити регистри и ремедиатион	P2	P1-02, P1-12
P2-12	Програмски интерфејс и апплицатион сецурити полициес	P2	P1-08, P1-10
P2-13	Депенденци и софтваре суппли-цхаин регистри	P2	P1-02, P2-11
P2-14	Endpoint/device труст и постуре	P2	P1-02, P1-12, P2-01
P2-15	Дата протецтион и ДЛП догађаји	P2	P1-07, P1-09, P1-14
P2-16	Бацкуп протецтион и рецовери ассуранце	P2	P1-02, P1-08, P2-05
P2-17	Сецурити телеметри ингестион и нормализација	P2	P1-19, P1-09, P1-12
P2-18	Контролисано дељење и трансфер осетљивих података	P2	P1-07, P1-20, P1-06, P1-09
P2-19	Криптографска политика и орцхестратион ротације	P2	P1-17, P2-05, P2-06, P1-08
P2-20	Сецурити баселине дрифт и ремедиатион	P2	P1-10, P1-16, P1-02, P1-12
P2-21	Цонсент лифецицле и преференце енфорцемент	P2	P1-21, P1-07, P1-09
P2-22	Сецурити траининг цампаигн развојни ток	P2	P1-22, P1-11, P1-09
P2-23	Полици ексцептион развојни ток и цомпенсатинг цонтролс	P2	P1-23, P1-16, P1-09
P2-24	Сервице-аццоунт преглед и стале-цредентиал цлеануп	P2	P1-24, P2-04, P2-05
P2-25	Сессион аномали и импоссибле-травел детецтион	P2	P2-02, P2-17, P1-13
P2-26	Девице куарантине и аццесс рестрицтион развојни ток	P2	P1-26, P2-14, P2-08
P2-27	Евиденце цоллецтион пацкаге и хандофф развојни ток	P2	P1-27, P2-10, P2-09
P2-28	Инцидент плаибоок ексецутион трацкинг	P2	P1-28, P2-09, P2-10
P2-29	Цровн-јевел аццесс надзор	P2	P1-29, P1-06, P2-17
P2-30	Цонтрол аттестатион и овнер фоллов-уп	P2	P1-30, P3-07, P1-09
P3-01	Полици енгине и атрибутска ауторизација	P3	P1-06, P1-07, P1-08
P3-02	Периодиц аццесс преглед и цертификатион	P3	P1-05, P2-03, P2-04
P3-03	Риск регистер и процена безбедносног ризика	P3	P1-02, P2-11
P3-04	Моделовање претњи развојни ток	P3	P1-02, P3-03
P3-05	Сецурити евент цоррелатион и аналитицс	P3	P1-09, P2-07
P3-06	Аутоматизација цонтаинмент и респонсе акција	P3	P2-02, P2-09, P2-05
P3-07	Цомплианце евиденце и цонтрол маппинг	P3	P1-08, P1-09
P3-08	Сецурити ексцептионс и риск аццептанце	P3	P1-08, P1-10, P3-03
P3-09	Пост-инцидент преглед и сецурити импровемент трацкинг	P3	P2-09, P2-10
P3-10	Аттацк-патх и експосуре графх анализа	P3	P1-02, P1-14, P2-11, P3-04
P3-11	Тхирд-парти и супплиер сецурити ассессмент	P3	P1-02, P1-16, P3-03
P3-12	Цонтинуоус цонтрол ефффецтивенесс и сецурити постуре	P3	P1-16, P3-05, P3-07
P3-13	Сегрегатион оф дутиес и токсиц-аццесс анализа	P3	P1-05, P1-06, P2-03, P3-02
P3-14	Риск-басед адаптиве аутхентицатион	P3	P2-01, P2-02, P2-14, P1-08
P3-15	Детецтион енгинееринг, симулација и тунинг правила	P3	P2-07, P2-17, P1-12
P3-16	Дата-аццесс аномали и ексфилтратион риск аналитика	P3	P1-07, P2-15, P2-17, P3-05

Ознака	Пројектна целина	Ниво	Главни предуслови
P3-17	Софтваре провенанце и релеасе труст верификација	P3	P2-13, P2-11, P1-16
P3-18	Приваци импацт и дата-процессинг ассессмент	P3	P1-07, P1-20, P3-03, P1-16
P3-19	Цриптограпхиц постуре и мигратион планнинг	P3	P1-17, P2-19, P3-10
P3-20	Сецурити метрицс, риск куантификатион и ексецутиве постуре	P3	P3-03, P3-05, P3-07, P3-12
P3-21	Дата-субјецт рекуест и приваци ригхтс развојни ток	P3	P1-21, P1-20, P2-18
P3-22	Хуман-риск аналитицс и таргетед аваренесс планнинг	P3	P1-22, P2-22, P3-05
P3-23	Ексцептион портфолио риск аналитицс	P3	P1-23, P2-23, P3-03
P3-24	Нон-хуман идентити постуре аналитицс	P3	P1-24, P2-24, P3-12
P3-25	Идентити тхреат хунтинг нотебоок	P3	P2-17, P2-25, P3-05
P3-26	Зеро-труст реадинесс и матурити ассессмент	P3	P1-14, P2-14, P3-12
P3-27	Евиденце куалити сцоринг и аудит реадинесс	P3	P1-27, P3-07, P2-27
P3-28	Сецурити аутоматион говернанце	P3	P1-28, P3-06, P3-08
P3-29	Цровн-јевел риск сценарио аналисис	P3	P1-29, P3-03, P3-10
P3-30	Цонтрол ассуранце роадмап и гап планнинг	P3	P1-30, P3-12, P3-20

7 Пројектне целине нивоа P1

Целине P1 формирају основни модел идентитета, ассет-а, приступа, класификације, полици-ја и аудит-а.

P1-01. Организације, безбедносни домени и власништво

Модел организационих целина, безбедносних домена и одговорности над ресурсима.

Табела 7. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Организатион, SecurityDomain, Овнер, Цритицалити, Обухват
Предуслови	Нема обавезних функционалних предуслова.

Обавезни случајеви употребе

- креирање организације и безбедносног домена
- додела власника
- повезивање ресурса са доменом
- промена критичности
- деактивација домена

Кључна безбедносна правила

- сваки заштићени ресурс мора имати власника или експлицитно дефинисан системски обухват
- деактивиран домен не прима нове ресурсе
- промена власништва мора бити аудитована

Могућа проширења

- хијерархија домена
- делегирани овнер
- схаред овнерсхип полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-02. Ассет инвентори и критичност ресурса

Централна евиденција апликација, сервиса, уређаја, података и других информационих ресурса.

Табела 8. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Ассет, AssetType, AssetOwner, Критицалити, LifecycleStatus
Предуслови	P1-01

Обавезни случајеви употребе

- регистрација ассет-а
- додела власника
- класификација критичности
- промена статуса
- претрага по домену и власнику

Кључна безбедносна правила

- ассет мора имати јединствен идентитет
- декомисиониран ассет остаје у историји
- критичност мора бити експлицитна и аудитована

Могућа проширења

- депенденци линк
- бусинесс сервице мап
- ассет импорт

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-03. Идентити регистри и животни циклус корисника

Управљање идентитетима запослених, сарадника и других људских корисника.

Табела 9. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Идентити, Персон, Аццоунт, IdentityStatus, EmploymentContext
Предуслови	Нема обавезних функционалних предуслова.

Обавезни случајеви употребе

- креирање идентитета
- aktiviranje/suspenzija
- повезивање налога
- промена статуса
- гашење приступа при престанку ангажмана

Кључна безбедносна правила

- једна особа не сме неконтролисано имати више неповезаних привилегованих идентитета
- суспендован идентитет не може добити нову сесију
- гашење мора уклонити активне привилегије према политици

Могућа проширења

- екстернал идентитиес
- идентити мерге
- темпорари цонтрацтор лифецицле

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-04. Основна аутентикација

Поуздана потврда идентитета корисника коришћењем стандардних механизама и библиотека.

Табела 10. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Цредентиал, AuthenticationAttempt, AuthenticationOutcome, PasswordPolicy, LockoutState
Предуслови	P1-03

Обавезни случајеви употребе

- пријава корисника
- одбијање неисправних података
- контролисани lockout/rate полици
- промена креденцијала
- опоравак приступа кроз симулирани канал

Кључна безбедносна правила

- лозинке се не чувају у отвореном облику
- сопствени криптографски алгоритми нису дозвољени
- одговор не сме непотребно откривати да ли налог постоји
- аутх отказ мора бити аудитован

Могућа проширења

- пассвордлесс адаптер
- екстернал ИдП
- риск-басед аутхентицатион сигнал

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-05. Улоге и основни Контрола приступа заснована на улогама

Модел улога и дозвола над функционалним целинама система.

Табела 11. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Роле, Пермиссион, Ассигнмент, Обухват, EffectivePermission
Предуслови	P1-03

Обавезни случајеви употребе

- креирање улоге
- додела дозволе
- додела улоге кориснику
- укидање улоге
- израчунавање ефективних дозвола

Кључна безбедносна правила

- дозвола се проверава серверски
- улога не сме имплицитно давати приступ изван обухвата
- привилегована додела се аудит-ује

Могућа проширења

- роле хиерарцхи
- сцопед роле
- сепаратион-оф-дутиес руле

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-06. Објецт-левел аутхоризатион и власништво ресурса

Провера да ли корисник сме приступити конкретном објекту, не само типу крајња тачка-а.

Табела 12. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ProtectedResource, ResourceOwner, AccessDecision, Субјецт, Ацтион
Предуслови	P1-05, P1-02

Обавезни случајеви употребе

- провера власништва
- провера обухвата
- dozvola/odbijanje конкретне операције
- промена овнер-а
- негативни приступ туђем ресурсу

Кључна безбедносна правила

- познавање ресоурце ИД-а није право приступа
- УИ филтер не замењује серверску ауторизацију
- сваки дени треба дати контролисан исход без цурења података

Могућа проширења

- схаред ресоурце аццесс
- делегатион
- ресоурце гроуп полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-07. Класификација података и правила руковања

Класификовање података према осетљивости и везивање безбедносних правила за класификацију.

Табела 13. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DataClassification, HandlingRule, RetentionClass, Сенситивити, DataOwner
Предуслови	P1-02

Обавезни случајеви употребе

- дефинисање класификационог нивоа
- додела класификације resursu/dokumentu
- валидација дозвољеног руковања
- промена класификације
- преглед класификованих ресурса

Кључна безбедносна правила

- класификација мора имати власника и значење
- нижи ниво заштите не сме аутоматски преписати виши без одобрења
- ретентион и приступ морају користити активну класификацију

Могућа проширења

- дата лабелс
- хандлинг матрикс
- цросс-домаин схаринг руле

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-08. Сецурити полици каталог

Централизована евиденција безбедносних правила и њиховог опсега примене.

Табела 14. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityPolicy, PolicyVersion, PolicyScope, EffectivePeriod, PolicyStatus
Предуслови	P1-01

Обавезни случајеви употребе

- креирање политике

- верзионисање
- активирање нове верзије
- повезивање са domenom/asset-om
- архивирање старе верзије

Кључна безбедносна правила

- објављена политика се не мења у месту
- историјски догађај мора моћи да се повеже са политиком која је тада важила
- контрадикторне политике захтевају дефинисано правило приоритета

Могућа проширења

- полици инхеританце
- ексцептион линк
- полици преглед период

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-09. Аудит лог и безбедносни догађаји

Следљива евиденција значајних безбедносних и административних активности.

Табела 15. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityEvent, AuditEvent, Ацтор, Ацтион, Таргет, Оутцоме, CorrelationId
Предуслови	P1-03, P1-05

Обавезни случајеви употребе

- бележење пријаве и приступа
- бележење промене привилегије
- претрага догађаја
- корелација активности
- извоз ограниченог прегледа

Кључна безбедносна правила

- аудит запис се не мења након уписа
- тајне и креденцијали се не записују
- безбедносни догађај мора разликовати успешан и неуспешан исход

Могућа проширења

- тампер-евидент хасх
- ретентион
- евент северити

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-10. Сецуре цонфигуратион баселине

Дефинисање и провера минималних безбедносних конфигурационих захтева за апликације и сервисе.

Табела 16. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityBaseline, ConfigurationRule, TargetType, ComplianceStatus, ExceptionRef
Предуслови	P1-02, P1-08

Обавезни случајеви употребе

- креирање баселине-а
- повезивање правила са ассет типом
- провера конфигурације
- евиденција одступања
- одобравање изузетка кроз референцу

Кључна безбедносна правила

- тајна није конфигурациона вредност у плаин текст-у
- баселине мора имати верзију
- одступање не сме бити скривено променом очекиване вредности без политике

Могућа проширења

- енвиронмент-специфиц баселине
- аутоматед цонфиг сцан
- баселине инхеританце

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-11. Сецурити нотификатионс и одговорни контакти

Обавештавање одговорних особа о безбедносно релевантним променама и догађајима.

Табела 17. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityNotification, Реципиент, Цханнел, NotificationType, DeliveryStatus
Предуслови	P1-01, P1-09

Обавезни случајеви употребе

- слање упозорења
- обавештење власника ресурса
- обавештење о промени привилегије
- праћење статуса
- поновни покушај кроз симулатор

Кључна безбедносна правила

- нотификатион отказ не сме рушити основну безбедносну одлуку
- дуплирани догађај не треба неконтролисано да генерише дупликате

- обавештење не садржи тајне

Могућа проширења

- дигест
- есцалатион
- куиет хоурс полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-12. Сецурити симулатори и тест идентитиес

Контролисано симулирање спољних идентитета, Вишефакторска аутентикација одговора, безбедносних догађаја и скенерских налаза.

Табела 18. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SimulatorProfile, TestIdentity, SecuritySignal, Сценарио, SimulationOutcome
Предуслови	Нема обавезних функционалних предуслова.

Обавезни случајеви употребе

- симулација ИдП одговора
- симулација OTP/MFA тока
- генерисање сецурити евент-а
- генерисање вулнерабилити финдинг-а
- поновљив сценарио

Кључна безбедносна правила

- симулатор не имплементира реални напад над спољним системом
- сценарио мора бити поновљив
- тест идентитети се јасно одвајају од реалних налога

Могућа проширења

- сценарио либрари
- цонтроллед отказ
- тиме-басед симулатион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-13. Безбедносна могућност посматрања система основа

Заједничка правила за цорреlатион, структурисане логове и основне сецурити метрике.

Табела 19. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TraceContext, SecurityMetric, LogEvent, CorrelationId, SourceComponent
Предуслови	P1-09

Обавезни случајеви употребе

- пропагација цоррелатион ид-а
- структурисани лог
- сецурити counter/metrika
- преглед хеалтх сигнала
- повезивање догађаја кроз компоненте

Кључна безбедносна правила

- логови не садрже лозинке, токен вредности или тајне
- сецурити метриц мора имати јасно значење
- цоррелатион не сме бити једини механизам ауторизације

Могућа проширења

- дистрибутед трацинг
- SLO/SLA сецурити метрицс
- самплинг полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-14. Сецурити зоне и труст-боундари регистри

Експлицитна евиденција труст зона, граница поверења и дозвољених токова између ассет-а ради доследног тхреат моделовања и ауторизационих одлука.

Табела 20. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TrustZone, TrustBoundary, DataFlow, EntryPoint, BoundaryOwner, TrustLevel
Предуслови	P1-01, P1-02

Обавезни случајеви употребе

- креирање труст зоне и додела власника
- повезивање ассет-а са једном или више релевантних зона
- евиденција дата флов-а који прелази труст боундари
- регистрација entry/exit поинт-а и протокола на концептуалном нивоу
- преглед свих цроссинг-а према зони и ассет-у
- деактивација или промена зоне уз импацт преглед постојећих токова

Кључна безбедносна правила

- сваки труст-боундари цроссинг мора имати јасан извор, одредиште и власника
- spoljni/nepoznati извор не добија имплицитно поверење
- промена зоне ассет-а мора покренути преглед релевантних полици и тхреат претпоставки
- регистри не представља фиревалл конфигурацију и не сме глумити реалну мрежну заштиту

Могућа проширења

- дата-флов диаграм из регистра
- зоне инхеританце
- интеграција са полици енгине-ом као децисион инпут

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-15. Дата ретентион и сецуре диспосал полици

Модел правила колико дуго се подаци чувају, када се могу безбедно уклонити и како се евидентира legal/operational холд.

Табела 21. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	RetentionPolicy, DataClass, RetentionPeriod, LegalHold, DisposalRequest, DisposalEvidence
Предуслови	P1-07, P1-08

Обавезни случајеви употребе

- дефинисање ретентион правила по класификацији података
- повезивање dataset/asset типа са правилом задржавања
- израчунавање планираног датума истека
- постављање и уклањање legal/operational холд-а
- одобравање сецуре диспосал захтева
- евиденција доказа да је симулирано уклањање завршено према политици

Кључна безбедносна правила

- активан холд спречава диспосал без експлицитно дозвољене процедуре
- промена ретентион правила мора бити верзионисана и не сме ретроактивно сакрити претходни захтев
- диспосал евиденце не сме садржати саму осетљиву вредност која је уклоњена
- истек периода не значи аутоматско физичко брисање без успешног развојни ток-а

Могућа проширења

- граце период и преглед пре диспосал-а
- полици конфликт ресолвер
- ретентион дасхбоард по дата класи

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-16. Каталог безбедносних контрола и власништво

Централни каталог техничких и процесних сецурити контрола, њихових власника, очекиваних доказа и статуса имплементације.

Табела 22. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityControl, ControlOwner, ControlType, ImplementationStatus, EvidenceRequirement, ReviewCycle
Предуслови	P1-01, P1-08

Обавезни случајеви употребе

- регистрација секурити контроле и њеног циља
- додела контрол овнер-а
- повезивање контроле са полици захтевом или ассет обухват-ом
- дефинисање очекиваног типа доказа и периода прегледа
- промена имплементатион статуса уз образложење
- преглед контрола без власника, доказа или актуелног преглед-а

Кључна безбедносна правила

- контрола без власника мора бити означена као говернанце гап
- само постојање контролног записа не доказује да је контрола ефективна
- промена циља или обухвата контроле мора бити аудитована
- контрола повучена из употребе остаје у историји ради следљивости претходних доказа

Могућа проширења

- цонтрол family/hierarchy
- мапирање на више интерних стандарда
- аутоматски преглед реминдер

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P1-17. Цриптографхиц ассет инвентори

Централна евиденција криптографских средстава и референци на кључеве, сертификате и тајне без чувања њиховог осетљивог садржаја.

Табела 23. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CryptoAsset, KeyReference, CertificateReference, SecretReference, Алгоритхм, Овнер
Предуслови	P1-01, P1-02, P1-08

Обавезни случајеви употребе

- регистрација криптографског средства и његове намене
- додела власника, система и безбедносног домена
- евиденција алгоритма, дужине и статуса без излагања тајног материјала
- повезивање са апликацијом, сервисом или уређајем
- праћење периода важења и планираног датума ротације
- означавање средства као compromised/revoked/retired
- преглед криптографских средстава по власнику, типу и критичности

Кључна пословна правила

- инвентар не сме чувати приватни кључ или плаинтекст сецрет
- свако активно средство мора имати власника и намену
- истекло или ревокед средство не сме бити приказано као важеће
- историја статуса и ротација мора остати следљива
- алгоритам означен као забрањен политиком мора произвести налаз

Могућа проширења

- црипто полици каталог
- импорт метадата из PKI/vault симулатора
- упозорења на скори истек

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-18. Екстернал експосуре и аттацк-сурфаце регистри

Евиденција споља изложених сервиса, крајња тачка-а, портова и домена ради разумевања аттацк сурфаце-а организације.

Табела 24. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Експосуре, InternetEndpoint, ServicePort, DomainName, ExposureOwner, ExposureStatus
Предуслови	P1-02, P1-14

Обавезни случајеви употребе

- регистрација споља доступног крајња тачка-а или сервиса
- повезивање експосуре-а са ассет-ом, власником и сецурити зоном
- евиденција протокола, порта и намене
- означавање одобреног, привременог или непознатог експосуре-а
- периодична потврда да је експосуре и даље потребан
- затварање експосуре записа након уклањања са спољне површине
- преглед експосуре-а по критичности и власнику

Кључна пословна правила

- сваки активни експосуре мора имати власника и пословно образложење
- непознат експосуре мора бити означен за проверу, не аутоматски проглашен рањивошћу
- затворен експосуре остаје у историји
- промена изложености критичног сервиса мора бити аудитована
- крајња тачка детаљи доступни су само у оквиру дозвољеног сецурити обухвата

Могућа проширења

- симулирани екстернал дисцовери феед
- DNS/TLS метадата
- аттацк-сурфаце тренд по периоду

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-19. Сецурити дата-соурце и лог-соурце регистри

Каталог извора безбедносних догађаја, логова и телеметри података са информацијама о власнику, шеми, квалитету и очекиваној доступности.

Табела 25. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityDataSource, LogSource, EventSchema, SourceOwner, CollectionStatus, DataQuality
Предуслови	P1-09, P1-13

Обавезни случајеви употребе

- регистрација security/log извора
- повезивање извора са ассет-ом, сервисом или доменом
- дефинисање очекиване шеме и категорија догађаја
- промена цоллецтион статуса и разлога прекида
- праћење последњег примљеног догађаја и фресхнесс-а
- евиденција дата-куалити проблема
- преглед цовераге-а кључних ассет-а сецурити изворима

Кључна пословна правила

- извор мора имати власника и јасно дефинисану сврху прикупљања
- губитак извора не сме бити представљен као одсуство безбедносних догађаја
- шема мора бити верзионисана када се семантика промени
- приступ осетљивим лог метадата мора поштовати сецурити обухват
- дата-куалити проблем мора остати следљив до извора и периода

Могућа проширења

- лог онбоардинг цхецклист
- соурце цритицалити сцоре
- симулатор прекида лог феед-а

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-20. Дата-флов и процессинг регистри

Модел кључних токова података између система, труст зона и организација ради подршке тхреат моделингу, класификацији и процени заштите података.

Табела 26. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DataFlow, DataStore, ProcessingPurpose, SourceSystem, DestinationSystem, TrustBoundary
Предуслови	P1-07, P1-14, P1-02

Обавезни случајеви употребе

- регистрација тока података између извора и одредишта
- додела класификације података који се преносе
- евиденција пословне сврхе и власника тока
- означавање преласка труст боундари-ја
- повезивање тока са сервисом, Програмски интерфејс-јем или складиштем
- промена или деактивација тока уз историју
- преглед токова који преносе осетљиве класе података

Кључна пословна правила

- активан ток осетљивих података мора имати власника и документовану сврху
- прелазак труст границе мора имати дефинисану заштитну контролу или експлицитан гап
- деактивација тока не брише историјски модел
- класификација одредишног податка не сме бити тихо нижа од политике без одобреног правила
- модел не сме садржати стварне тајне или пуни садржај корисничких података

Могућа проширења

- визуелни ДФД приказ
- дата ресиденци метадата
- аутоматско обогаћивање тхреат модела

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-21. Цонсент и лавфул-басис регистри

Евиденција основа обраде, цонсент статуса и сврхе обраде када се заштићени подаци користе кроз више апликација или пословних процеса.

Табела 27. Елемен̄т и Сп̄ецификација

Елемент	Спецификација
Кључни појмови	ConsentRecord, LawfulBasis, ProcessingPurpose, DataSubjectCategory, ConsentStatus
Предуслови	P1-07, P1-20

Обавезни случајеви употребе

- регистрација лавфул-басис основа за ток или обраду података
- евиденција цонсент статуса по субјекту, сврси и систему
- промена или повлачење цонсент-а уз историју
- преглед активних обрада без познатог основа
- повезивање consent/lawful-basis записа са дата-флов регистри-јем
- извоз минималног аудит доказа за одлуку о обради

Кључна безбедносна правила

- обрада која захтева цонсент не сме бити означена као дозвољена без активног цонсент записа
- повлачење цонсент-а не брише историјски аудит доказ
- лавфул басис, пурпосе и дата цатегори морају бити експлицитни
- обухват цонсент-а не сме бити проширен без нове одлуке или правила
- евиденце не сме садржати непотребне личне податке

Могућа проширења

- преференце центар
- дата-субјецт нотице темплате
- полици маппинг по јурисдикцији без правног сертификовања

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-22. Сецурити траининг и аваренесс регистри

Евиденција безбедносних тренинга, циљних група и статуса завршетка ради подршке аваренесс кампањама и мерењу обавеза.

Табела 28. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TrainingModule, AudienceGroup, TrainingAssignment, CompletionStatus, AwarenessTopic
Предуслови	P1-01, P1-03

Обавезни случајеви употребе

- креирање модула безбедносне обуке
- додела модула циљној групи или улози
- евиденција завршетка и резултата kviza/simulacije
- преглед корисника са истеклом или незавршеном обуком
- верзионисање садржаја обуке
- деактивација модула уз очување историје

Кључна безбедносна правила

- обавезна обука мора имати циљну групу, рок и овнер-а
- промена садржаја не сме ретроактивно изменити претходно завршене записе
- статус завршетка мора бити везан за корисника и верзију модула
- обука не сме садржати стварне тајне или реалне пхисхинг линкове

Могућа проширења

- аваренесс сцоре
- реминдер политика
- симулирани пхисхинг као контролисана едукативна вежба без стварне инфраструктуре

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-23. Ексцептион и полици ваивер цаталог

Каталог изузетака од безбедносних политика и ваивер записа који омогућавају контролисано праћење разлога, обухвата и датума истека.

Табела 29. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	PolicyException, Ваивер, CompensatingControl, ExpiryDate, ExceptionOwner
Предуслови	P1-08, P1-16

Обавезни случајеви употребе

- креирање захтева за изузетак од политике
- додела овнер-а и риск образложења
- повезивање изузетка са контролом и ассет-ом
- дефинисање цомпенсатинг цонтрол записа
- преглед активних и истеклих изузетака
- деактивација или затварање изузетка уз доказ

Кључна безбедносна правила

- изузетак мора имати разлог, обухват, овнер-а и датум истека
- истекао изузетак не сме валидирати неусаглашено стање
- цомпенсатинг цонтрол мора бити проверљив или означен као планиран
- изузетак не сме служити као трајна замена за политику без одлуке наставног тима

Могућа проширења

- аппровал развојни ток
- булк преглед кампања
- ексцептион хеатмап

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-24. Machine/service аццоунт овнерсхип регистри

Евиденција нон-хуман идентитета, њихових овнер-а, сврхе и минималног обухвата ради контроле сервисних налога и аутоматизованих интеграција.

Табела 30. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ServiceAccount, MachineIdentity, Овнерсхип, CredentialBinding, AllowedScope
Предуслови	P1-02, P1-03, P1-05

Обавезни случајеви употребе

- регистрација сервице аццоунт-а или мацхине идентити-ја
- додела техничког и пословног овнер-а
- евиденција сврхе и дозвољеног обухвата
- повезивање идентитета са цредентиал записом без чувања тајне
- преглед налога без овнер-а или са прешироким обухват-ом
- деактивација идентитета уз очување историје

Кључна безбедносна правила

- сервице аццоунт не сме бити активан без овнер-а и сврхе
- дозвољени обухват мора бити експлицитно наведен
- тајни материјал се не чува у регистри-ју
- промена овнер-а или обухвата мора оставити аудит траг
- деактивиран идентитет не сме бити понуђен као активан цонсумер-у

Могућа проширења

- наминг стандард
- овнер аттестатион
- стале аццоунт кандидати

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-25. Токен, сессион и цредентиал метадата регистри

Евиденција метадата о токенима, сесијама и цредентиал типовима без чувања самих тајни, ради подршке ревоцатион-у, аудит-у и полици одлукама.

Табела 31. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TokenFamily, SessionMetadata, CredentialType, Иссуер, AssuranceLevel, RevocationState
Предуслови	P1-04, P1-09

Обавезни случајеви употребе

- регистрација token/session фамили типа
- евиденција иссуер-а, ассуранце нивоа и рока важења
- повезивање сессион метадата са аудит догађајем
- означавање revoked/expired статуса
- преглед токен типова са предугим важењем
- деактивација цредентиал типа

Кључна безбедносна правила

- вредност токена или лозинке се никада не складишти
- метадата мора бити довољан за ревоцатион и аудит без откривања тајне
- ревокед статус мора бити једнозначан
- иссуер и ассуранце левел морају бити познати за безбедносно значајне одлуке

Могућа проширења

- токен фамили висуализатион
- сессион инвентори дасхбоард
- риск тагс по типу цредентиал-а

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-26. Крајња тачка и девице инвентори труст атрибути

Основни регистри уређаја и крајња тачка труст атрибута који омогућава касније постуре процене и аццесс одлуке.

Табела 32. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Девице, Крајња тачка, DeviceOwner, PostureAttribute, EnrollmentStatus, TrustLevel
Предуслови	P1-02, P1-14

Обавезни случајеви употребе

- регистрација уређаја или крајња тачка-а
- додела овнер-а и сецурити домена
- евиденција енроллмент и постуре атрибута
- промена труст левел-а уз разлог
- преглед непознатих или унманагед уређаја
- деактивација изгубљеног или повученог уређаја

Кључна безбедносна правила

- уређај без овнер-а не сме имати висок труст левел
- постуре атрибути морају имати извор и време последње провере

- труст левел је метадата за одлуку, не гаранција безбедности
- деактивиран уређај не сме бити понуђен као валидан крајња тачка

Могућа проширења

- МДМ симулатор
- девице риск лабел
- привремено трустед стање са роком

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-27. Евиденце репозиторијум и цхаин-оф-цустоди основа

Основни репозиторијум доказа за сецурити догађаје, инциденте и контроле, са метаподацима о пореклу, интегритету и приступу.

Табела 33. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	EvidenceItem, ChainOfCustody, EvidenceSource, HashRecord, AccessLog
Предуслови	P1-09, P1-16

Обавезни случајеви употребе

- креирање евиденце итем-а без чувања непотребног садржаја
- повезивање доказа са инцидентом, контролом или налазом
- евиденција извора и времена прикупљања
- евиденција hash/integrity метадата
- контролисан приступ доказу
- преглед цхаин-оф-цустоди записа

Кључна безбедносна правила

- евиденце итем мора имати извор, овнер-а и класификацију
- приступ доказу мора бити аудитован
- промена метадата не сме избрисати претходни цхаин-оф-цустоди запис
- доказ не сме садржати лозинке, токене или непотребне личне податке

Могућа проширења

- експорт евиденце пацкаге
- интегрити верификатион симулатор
- ретентион полици по типу доказа

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-28. Сецурити плаибоок каталог

Каталог стандардизованих плаибоок корака за инциденте и оперативне безбедносне процесе, без аутоматског извршавања стварних акција.

Табела 34. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Плаибоок, PlaybookStep, TriggerCondition, RequiredRole, SafetyCheck

Елемент	Спецификација
Предуслови	P1-11, P1-16

Обавезни случајеви употребе

- креирање плаибоок-а за сецурити сценарио
- дефинисање корака и предуслова
- додела одговорне улоге по кораку
- верзионисање плаибоок-а
- деактивација застарелог плаибоок-а
- преглед плаибоок-а релевантних за тип инцидента

Кључна безбедносна правила

- плаибоок корак мора имати јасну намену и очекивани доказ извршења
- опасна акција мора имати сафети цхецк или ознаку да је ручна
- промена плаибоок-а не мења историју извршених случајева
- плаибоок не сме садржати стварне тајне или инструкције за напад на реалне системе

Могућа проширења

- плаибоок темплате-и
- северити-басед варијанте
- маппинг на МИТРЕ технику као едукативни метадата

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-29. Бусинесс импацт и цровн-јевел маппинг

Класификација најкритичнијих ассет-а, процеса и података ради приоритизације заштите, ризика и надзор фокуса.

Табела 35. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CrownJewelAsset, BusinessImpact, CriticalProcess, ImpactCategory, RecoveryPriority
Предуслови	P1-01, P1-02, P1-07

Обавезни случајеви употребе

- означавање цровн-јевел ассет-а или процеса
- додела бусинесс импацт категорије
- повезивање ассет-а са власником и класификацијом података
- преглед критичних ресурса без контроле или овнер-а
- промена импацт процене уз образложење
- деактивација ознаке када ассет више није критичан

Кључна безбедносна правила

- цровн-јевел ознака мора имати овнер-а и разлог
- висок импацт не сме бити аутоматски изједначен са високим ризиком без threat/kontrolnog контекста
- промена импацт-а мора оставити аудит траг
- критичан ресурс без овнер-а представља гап

Могућа проширења

- импацт хеатмап
- бусинесс процесс мап
- приорити таг за инцидент триаге

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P1-30. Цонтрол овнерсхип и респонсибилити матрикс

Матрица одговорности над безбедносним контролама, овнер-има, евиденцијом и проверама ефективности.

Табела 36. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ControlOwner, ResponsibilityMatrix, РАЦИ, EvidenceRequirement, ReviewCadence
Предуслови	P1-01, P1-08, P1-16

Обавезни случајеви употребе

- додела овнер-а безбедносној контроли
- дефинисање РАЦИ улога
- повезивање контроле са очекиваним евиденце-ом
- дефинисање цаденце-а провере
- преглед контрола без овнер-а или евиденце захтева
- промена одговорности уз историју

Кључна безбедносна правила

- активна контрола мора имати овнер-а
- контрола која захтева евиденце мора навести тип доказа
- РАЦИ улоге не смеју бити контрадикторне
- промена овнер-а не сме обрисати претходну одговорност

Могућа проширења

- цонтрол цалендар
- овнерсхип дасхбоард
- булк реассигнмент

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

8 Пројектне целине нивоа P2

Целине P2 уводе активне механизме заштите, оперативне безбедносне процесе и реакцију на сецурити сигнал.

P2-01. Мулти-фацтор и степ-уп аутентикација

Додатна потврда идентитета за ризичне или привилеговане операције.

Табела 37. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	MfaChallenge, Фацтор, StepUpContext, ChallengeStatus, RiskReason

Елемент	Спецификација
Предуслови	P1-04, P1-12

Обавезни случајеви употребе

- покретање Вишефакторска аутентикација цхалленге-а
- потврда фактора кроз симулатор
- истек цхалленге-а
- степ-уп за привилеговану операцију
- одбијање ponovljenog/zastarelog цхалленге-а

Кључна безбедносна правила

- Вишефакторска аутентикација token/challenge има кратак век
- успешна основна пријава не значи аутоматски довољан ассуранце за сваку операцију
- реплаи цхалленге-а мора бити одбијен

Могућа проширења

- мултипле фацторс
- ремемберед девице полици
- риск-триггеред степ-уп

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-02. Сессионс, токенс и ревоцатион

Управљање активним сесијама и токенима без ослањања на бесконачно важење приступа.

Табела 38. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Сессион, AccessTokenRef, RefreshTokenRef, Ревоцатион, SessionState
Предуслови	P1-04, P1-09

Обавезни случајеви употребе

- креирање сесије
- обнова приступа
- укидање сесије
- укидање свих сесија корисника
- преглед активних сесија

Кључна безбедносна правила

- токен животни век мора бити коначан
- ревокед сессион не сме наставити да добија приступ
- токен вредности се не записују у лог

Могућа проширења

- девице-боунд сессион
- сессион риск сцоре
- цонцуррент сессион полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-03. Привилегед Аццесс и Јуст-ин-Тиме приступ

Привремено додељивање привилегованих права уз одобрење, степ-уп и аутоматски истек.

Табела 39. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	PrivilegedAccessRequest, Аппровал, PrivilegeGrant, ExpiresAt, Ревоцатион
Предуслови	P1-05, P2-01

Обавезни случајеви употребе

- подношење захтева
- odobravanje/odbijanje
- степ-уп потврда
- активирање привилегије
- аутоматски истек
- хитно укидање

Кључна безбедносна правила

- привилегија мора имати разлог и рок
- одобрење и извршење могу захтевати сепаратион оф дутиес
- истекла привилегија се не ослања на ручно чишћење

Могућа проширења

- бреак-гласс аццесс
- дуал аппровал
- привилегед сессион преглед

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-04. Сервице идентитиес и радно оптерећење аутхентицатион

Идентитет и аутентикација aplikacija/servisa који међусобно комуницирају.

Табела 40. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ServiceIdentity, ClientCredentialRef, ServiceScope, TrustStatus, CredentialVersion
Предуслови	P1-02, P1-08

Обавезни случајеви употребе

- регистрација сервисног идентитета
- додела обухвата
- аутентикација сервиса
- укидање идентитета

- ротација приступног креденцијала

Кључна безбедносна правила

- људски налог се не користи као сервисни идентитет
- сервис добија минимално потребан обухват
- схаред цредентиал између више неповезаних сервиса није прихватљив

Могућа проширења

- радно оптерећење идентити
- схорт-ливед сервице токен
- сервице-то-сервице полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-05. Сецретс манагемент и лифецицле

Централно управљање тајнама и приступним креденцијалима уз контролисан приступ и ротацију.

Табела 41. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Сецрет, SecretVersion, SecretScope, Леасе, RotationPolicy
Предуслови	P2-04, P1-09

Обавезни случајеви употребе

- креирање тајне
- чување верзије
- контролисан приступ
- ротација
- ревоцатион
- аудит коришћења

Кључна безбедносна правила

- тајна се не чува у соурце цоде-у
- вредност тајне се не приказује кориснику који нема потребан обухват
- ротација не сме захтевати ручно мењање тајне на више места без евиденције

Могућа проширења

- сецрет леасе
- динамиц сецрет симулатор
- аутоматиц ротатион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-06. Цертификатес и кеи лифецицле

Евиденција и контролисани животни циклус сертификата и криптографских кључева користећи стандардне библиотеке и симулирану ЦА.

Табела 42. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Цертификате, KeyRef, Иссуер, ValidFrom, ValidTo, RevocationStatus
Предуслови	P1-12, P2-04

Обавезни случајеви употребе

- захтев за сертификатом
- издавање кроз симулатор ЦА
- провера важења
- обнова
- ревоцатион
- упозорење пред истек

Кључна безбедносна правила

- приватни кључ се не логује нити приказује непотребно
- istekao/revoked сертификат се не сматра важећим
- студент не имплементира сопствену криптографију

Могућа проширења

- цертификате инвентори
- кеи усаге полици
- аутоматиц реневал

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-07. Сецурити детецтион рулес

Правила која над безбедносним догађајима препознају сумњиве обрасце или кршење политике.

Табела 43. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DetectionRule, RuleCondition, Виндов, Северити, DetectionOutcome
Предуслови	P1-09, P1-12

Обавезни случајеви употребе

- креирање правила
- обрада сецурити евент-а
- детекција praga/obrasca
- suppression/deduplikacija
- промена северити-а

Кључна безбедносна правила

- правило мора имати објашњив услов
- један догађај не мора аутоматски значити инцидент
- фалсе positive/negative последице морају бити документоване

Могућа проширења

- виндовед цоррелатион
- мултипле евент типес
- руле тестинг харнесс

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-08. Сецурити алертс и триаге

Вођење алерт-а од детекције до одлуке да ли захтева инцидент или се затвара као нерелевантан сигнал.

Табела 44. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityAlert, AlertStatus, TriageDecision, Северити, Овнер
Предуслови	P2-07, P1-11

Обавезни случајеви употребе

- креирање алерт-а
- додела одговорног аналитичара
- триаге
- ескалација у инцидент
- затварање уз разлог

Кључна безбедносна правила

- затварање захтева разлог
- критицал алерт има експлицитну ескалацију
- дуплирани алерт-и не смеју неконтролисано стварати инциденте

Могућа проширења

- алерт гроупинг
- СЛА за триаге
- суппрессион полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-09. Сецурити инцидент манагемент

Вођење животног циклуса безбедносног инцидента од пријаве до затварања.

Табела 45. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityIncident, IncidentStatus, Северити, IncidentOwner, ContainmentStatus
Предуслови	P2-08, P1-02

Обавезни случајеви употребе

- отварање инцидента

- процена severity/impact-а
- додела овнер-а
- цонтаинмент статус
- рецовери статус
- затварање

Кључна безбедносна правила

- инцидент мора имати јасан обухват и погођене ассет-е где је познато
- затварање захтева резиме решења
- критичан инцидент не може нестати брисањем догађаја

Могућа проширења

- мајор инцидент моде
- инцидент СЛА
- инцидент цоммуницатион план

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-10. Инвестигатион, евиденце и тимелине

Структурисано прикупљање артефаката и временске линије током истраге инцидента.

Табела 46. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Евиденце, EvidenceType, TimelineEntry, Соурце, IntegrityMetadata
Предуслови	P2-09, P1-09

Обавезни случајеви употребе

- додавање доказа
- повезивање са инцидентом
- тимелине догађај
- контролисан приступ доказу
- извоз истраге

Кључна безбедносна правила

- евиденце се не мења без нове verzije/zapisa
- приступ доказима је строже контролисан од обичног инцидент прегледа
- интегрити метадата не сме бити представљена као форензички доказ ако механизам то не гарантује

Могућа проширења

- евиденце цхаин метадата
- аттацхмент хасхинг
- тимелине цоррелатион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-11. Вулнерабилити регистри и ремедиатион

Евиденција познатих слабости, налаза и плана отклањања без извођења напада над реалним системима.

Табела 47. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	VulnerabilityFinding, Северити, AffectedAsset, Ремедиатион, FindingStatus
Предуслови	P1-02, P1-12

Обавезни случајеви употребе

- увоз симулираног налаза
- повезивање са ассет-ом
- процена приоритета
- додела ремедиатион овнер-а
- затварање налаза уз доказ

Кључна безбедносна правила

- налаз без погођеног ассет-а мора остати јасно означен као непотпун
- северити није исто што и пословни риск
- затварање мора имати верификациони доказ

Могућа проширења

- ЦВСС-лике метадата
- exception/acceptance
- ретест развојни ток

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-часе сценарио.

P2-12. Програмски интерфејс и апплицатион сецурити полициес

Централизована правила за основну заштиту апликационих и Програмски интерфејс граница.

Табела 48. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ApiSecurityPolicy, EndpointClass, RatePolicy, InputPolicy, SecurityHeaderPolicy
Предуслови	P1-08, P1-10

Обавезни случајеви употребе

- повезивање крајња тачка-а са полици класом
- провера auth/authz захтева
- рате полици
- инпут size/shape ограничење
- сецурити цонфигуратион цхецк

Кључна безбедносна правила

- валидација инпут-а не замењује пословну валидацију
- рате лимит мора имати јасан обухват

- сецурити хеадер или Програмски интерфејс полици мора бити тестиран, не само документован

Могућа проширења

- ЦОРС полици регистри
- Програмски интерфејс клијент полици
- гатеваи интегратион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-13. Депенденци и софтваре суппли-цхаин регистри

Евиденција софтверских зависности, пакета и познатих ризика у ланцу испоруке.

Табела 49. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SoftwareComponent, Депенденци, Версион, Соурце, KnownRisk
Предуслови	P1-02, P2-11

Обавезни случајеви употребе

- регистрација компоненте
- увоз депенденци листе
- повезивање налаза са верзијом
- upgrade/remediation план
- евиденција одобреног изузетка

Кључна безбедносна правила

- пакет мора имати идентитет и верзију
- непознат извор зависности мора бити видљив риск сигнал
- затварање ризика захтева novu/verifikovanu верзију или прихваћен изузетак

Могућа проширења

- СБОМ импорт
- license/security метадата
- депенденци фресхнесс полици

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-14. Endpoint/device труст и постуре

Процена поверења у уређај са ког корисник приступа систему коришћењем симулираних постуре сигнала као додатног инпут-а безбедносне одлуке.

Табела 50. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DeviceIdentity, DevicePosture, TrustLevel, AttestationResult, PostureSignal, AccessSignal
Предуслови	P1-02, P1-12, P2-01

Обавезни случајеви употребе

- регистрација управљаног тест уређаја
- пријем симулираних постуре сигнала попут encryption/patch/agent статуса
- израчунавање тренутног труст нивоа према верзионисаној политици
- означавање изгубљеног или компромитованог уређаја
- излагање постуре сигнала authentication/policy компоненти
- негативни сценарио приступа са нон-цомплиант уређаја

Кључна безбедносна правила

- постуре сигнал мора имати време важења и не сме се трајно сматрати свежим
- девице труст не замењује идентити аутхентицатион
- непознат уређај мора имати експлицитан дефаулт третман
- осетљиви детаљи уређаја не смеју се непотребно излагати другим закупац-има или корисницима

Могућа проширења

- риск-басед степ-уп Вишефакторска аутентикација сигнал
- симулатор MDM/EDR извора
- трустед-девице енроллмент аппровал

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-15. Дата протецтион и ДЛП догађаји

Детекција и контролисан одговор на покушаје преноса класификованих података ка недозвољеном или високо-ризичном одредишту у сопственом тестном систему.

Табела 51. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DlpPolicy, DataMovement, DestinationClass, DlpDecision, DlpEvent, ExceptionRef
Предуслови	P1-07, P1-09, P1-14

Обавезни случајеви употребе

- дефинисање ДЛП правила према дата класи и дестинатион типу
- евалуација симулираног upload/export/email сценарија
- дозвола, упозорење или блокада према политици
- генерисање сецурити евент-а за релевантан покушај
- повезивање одобреног изузетка када постоји
- преглед поновљених или високоризичних ДЛП догађаја без откривања пуног садржаја

Кључна безбедносна правила

- ДЛП лог не сме складиштити пуну осетљиву вредност када је довољан fingerprint/metapodatak
- одлука мора узети у обзир класификацију и trust/destination контекст
- ексцептион мора имати обухват и рок важења
- пројекат не сме слати реалне осетљиве податке нити тестирати спољне сервисе без дозволе

Могућа проширења

- цонтент фингерпринт симулатор

- усер јустификатион развојни ток
- цоррелатион са инцидент модулом

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-16. Бацкуп протецтион и рецовери ассуранце

Безбедносна евиденција заштите бацкуп копија, приступа, енкрипционог статуса и периодичних ресторе провера без имплементације складиште података производа од нуле.

Табела 52. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ProtectedBackup, BackupPolicy, EncryptionStatus, AccessPolicy, RestoreTest, RecoveryEvidence
Предуслови	P1-02, P1-08, P2-05

Обавезни случајеви употребе

- регистрација бацкуп сета и припадајућег заштићеног ассет-а
- евиденција енцриптион и аццесс-полици статуса
- контрола ко сме покренути ресторе тест
- периодична провера čitljivosti/restore способности кроз симулатор
- евиденција неуспеха, застарелости или недостајућег бацкуп-а
- генерисање рецовери евиденце записа за преглед

Кључна безбедносна правила

- бацкуп који није потврђено заштићен не сме бити означен као цомплиант само зато што постоји
- ресторе тест се изводи у изолованом тестном обухват-у
- secret/key вредности се не чувају у бацкуп регистру
- доказ мора разликовати последњи успешан бацкуп од последњег успешног ресторе теста

Могућа проширења

- immutable/WORM статус симулатор
- дуал-цонтрол ресторе аппровал
- рансомваре рецовери таблетоп сценарио

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P2-17. Сецурити телеметри ингестион и нормализација

Пријем дефанзивних сецурити догађаја из више симулираних извора, валидација шеме и нормализација у заједнички безбедносни модел.

Табела 53. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityEvent, IngestionSource, NormalizedEvent, ParserVersion, QualityFlag, EventId
Предуслови	P1-19, P1-09, P1-12

Обавезни случајеви употребе

- пријем догађаја из симулираног log/security извора
- валидација минималних обавезних поља
- нормализација времена, идентитета, ассет референце и евент категорије
- означавање непознатог или делимично парсираног догађаја
- дедупликација идентичног евент-а према стабилном идентитету
- рутирање валидног догађаја ка детецтион слоју
- праћење парсер еррор рате-а и соурце фресхнесс-а

Кључна пословна правила

- невалидан догађај се не сме тихо претворити у валидан без куалити ознаке
- дупликат не сме неконтролисано произвести више истих довнстреам последица
- парсер верзија мора остати позната за историјски догађај
- ингестион не сме мењати изворни сецурити аудит запис
- очекивани прекид извора мора бити различит од нормалног одсуства догађаја

Могућа проширења

- батцх ингест
- деад-леттер сецурити евентс
- сцхема цомпатибилити тестови

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-18. Контролисано дељење и трансфер осетљивих података

Развојни ток одобравања и евидентирања трансфера класификованих података између корисника, система или труст зона.

Табела 54. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TransferRequest, DataPackage, Дестинатион, Аппровал, ProtectionRequirement, TransferOutcome
Предуслови	P1-07, P1-20, P1-06, P1-09

Обавезни случајеви употребе

- креирање захтева за дељење или трансфер класификованих података
- провера дестинатион труст зоне и дозвољене класификације
- одређивање потребних заштитних мера према полици-ју
- odobravanje/odbijanje захтева од одговарајуће улоге
- евиденција симулираног трансфера без чувања реалног осетљивог садржаја
- опозив или истек претходно одобреног трансфера
- аудит преглед трансфера по власнику и периоду

Кључна пословна правила

- корисник не може сам себи одобрити трансфер када политика захтева другу улогу
- трансфер у мање поуздану зону мора бити блокиран или имати експлицитан одобрен изузетак
- одобрење мора важити за конкретан обухват и период
- аудит не сме чувати тајни садржај трансферисаних података
- истекло одобрење не сме важити за нови трансфер

Могућа проширења

- watermark/tag метадата
- оне-тиме схаринг линк симулатор
- ДЛП догађај након покушаја недозвољеног трансфера

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-19. Криптографска политика и орцхестратион ротације

Планирање и контролисано спровођење ротације кључева, сертификата и тајни на основу криптографског инвентара и полици-ја.

Табела 55. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CryptoPolicy, RotationPlan, RotationStep, CryptoFinding, CompatibilityCheck, RollbackPlan
Предуслови	P1-17, P2-05, P2-06, P1-08

Обавезни случајеви употребе

- дефинисање дозвољених алгоритама и максималног периода коришћења
- детекција средства које крши криптографску политику
- креирање плана ротације са зависним сервисима
- провера да циљна апликација подржава нову verziju/algoritam
- симулирано активирање нове цредентиал верзије
- контролисано повлачење старе верзије након верификације
- роллбацк евиденција ако ротација прекине очекивани сервис

Кључна пословна правила

- ротација не сме излагати тајни материјал у логу или аудит-у
- стара верзија се не опозива пре дефинисане потврде када је потребан оверлап период
- план мора имати власника и recovery/rollback корак за критичне системе
- крипто полици мора бити верзионисана
- цомпромисед средство може захтевати убрзану ротацију која се јасно разликује од планиране

Могућа проширења

- масс ротатион цампаигн
- алгоритхм мигратион планнинг
- симулатор сервице-а који не подржава нову верзију

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-20. Сецурити баселине дрифт и ремедиатион

Аутоматизовано или симулирано поређење ассет конфигурације са безбедносним баселине-ом и праћење процеса корекције.

Табела 56. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityBaseline, ConfigurationSnapshot, DriftFinding, Ремедиатион, Ексцептион, Верификатион
Предуслови	P1-10, P1-16, P1-02, P1-12

Обавезни случајеви употребе

- пријем симулираног цонфигуратион снапсхот-а
- евалуација снапсхот-а према важећем сецурити баселине-у
- отварање налаза за неусаглашену контролу
- додела ремедиатион власника и рока
- одобравање временски ограниченог изузетка
- поновна провера након корекције
- затварање налаза уз доказ верификације

Кључна пословна правила

- баселине мора бити верзионисан и везан за тип ассет-а
- налаз мора садржати довољно метадата за репродукцију без откривања тајни
- изузетак мора имати разлог, власника и датум истека
- затварање захтева нову проверу или други прихватљив доказ
- критични дрифт може повећати риск сцоре али не сме аутоматски мењати процену без документоване формуле

Могућа проширења

- цомплианце сцоре
- булк ремедиатион цампаигн
- интегратион са цханге манагемент симулатором

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-21. Цонсент лифецицле и преференце енфорцемент

Оперативни ток којим се consent/preference одлуке проверавају при приступу подацима и пропагирају до цонсумер процеса.

Табела 57. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ConsentDecision, PreferenceSnapshot, EnforcementCheck, WithdrawalEvent, ProcessingBlock
Предуслови	P1-21, P1-07, P1-09

Обавезни случајеви употребе

- евалуација да ли је обрада дозвољена за сврху
- блокирање обраде након повлачења цонсент-а
- креирање витхдравал евент-а
- пропагација промене преференце-а ка цонсумер адаптеру
- аудит allow/deny одлуке
- преглед процеса погођених повлачењем цонсент-а

Кључна безбедносна правила

- витхдравал мора произвести проверљив security/privacy евент
- стари цонсент снапсхот не сме валидирати нову сврху
- обрада без познатог основа мора добити детерминистичан дени или рекуирес-преглед исход
- цонсумер не сме добити више података него што је потребно за енфорцемент

Могућа проширења

- преференце синц симулатор
- граце-период правила
- приваци дасхбоард

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-22. Сецурити траининг цампаигн развојни ток

Планирање, извршавање и праћење аваренесс кампање са контролисаним обавештењима и доказима завршетка.

Табела 58. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	TrainingCampaign, AssignmentBatch, Реминдер, CompletionEvidence, CampaignStatus
Предуслови	P1-22, P1-11, P1-09

Обавезни случајеви употребе

- креирање кампање за циљну групу
- генерисање ассигнмент-а
- слање симулираног реминдер-а
- праћење статуса по кориснику
- ескалација ка одговорној групи за кашњења
- затварање кампање уз извештај

Кључна безбедносна правила

- кампања мора имати обухват, рок и овнер-а
- реминдер не сме излагати осетљиве детаље другим корисницима
- статус завршетка мора референцирати верзију модула
- кампања не сме користити реалне пхисхинг линкове или обмањујућу инфраструктуру

Могућа проширења

- адаптиве реминдерс
- аваренесс тренд
- роле-басед цампаигн темплатес

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-23. Полици ексцептион развојни ток и цомпенсатинг цонтролс

Контролисани процес од захтева за полици изузетак до одлуке, цомпенсатинг цонтрол-а и истека.

Табела 59. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ExceptionRequest, ApprovalDecision, CompensatingControl, ExpiryReview, ExceptionRisk
Предуслови	P1-23, P1-16, P1-09

Обавезни случајеви употребе

- отварање захтева за изузетак
- додела ризика и цомпенсатинг цонтрол-а
- одобравање или одбијање захтева
- обавештење пред истек изузетка
- периодична ре-евалуација активних изузетака
- затварање изузетка и верификација стања

Кључна безбедносна правила

- одобрен изузетак мора имати рок истека
- цомпенсатинг цонтрол мора бити повезан са конкретном контролом или гап-ом
- истек изузетка мора произвести јасно оперативно стање
- неодобрен захтев не сме мењати статус контроле

Могућа проширења

- мулти-степ аппровал
- ексцептион преглед боард симулатор
- риск аццептанце пакет

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-24. Сервице-аццоунт преглед и стале-цредентиал цлеануп

Периодична провера нон-хуман идентитета, њихових овнер-а и цредентиал метадата ради уклањања застарелих или прешироких права.

Табела 60. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ServiceAccountReview, StaleCredential, ScopeFinding, CleanupAction, ReviewOutcome
Предуслови	P1-24, P2-04, P2-05

Обавезни случајеви употребе

- покретање преглед кампање за сервице аццоунт-е
- идентификација налога без овнер-а или активности
- детекција прешироког обухвата
- предлог ротације или деактивације цредентиал-а
- потврда овнер-а или цлеануп акције
- аудит преглед исхода

Кључна безбедносна правила

- цлеануп не сме аутоматски обрисати тајну без контролисане одлуке

- стале статус мора имати критеријум и податке на основу којих је утврђен
- овнер мора потврдити пословну сврху критичног сервице аццоунт-а
- преглед исход мора бити аудитабилан

Могућа проширења

- аттестатион развојни ток
- риск сцоре за нон-хуман идентити
- булк цредентиал ротатион цандидате лист

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-25. Сессион аномали и импоссибле-травел детецтион

Детекција неуобичајених сесијских образаца кроз објашњива правила и контролисане симулиране податке.

Табела 61. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SessionAnomaly, LoginEvent, GeoVelocity, DeviceChange, AnomalyFinding
Предуслови	P2-02, P2-17, P1-13

Обавезни случајеви употребе

- пријем login/session догађаја
- евалуација импоссибле-травел правила
- детекција нагле промене уређаја или локације
- генерисање аномали финдинг-а
- повезивање налаза са корисником и сесијом
- потврда, одбацивање или ескалација налаза

Кључна безбедносна правила

- налаз је индикација, не доказ компромитације
- правила морају бити детерминистичка за исте улазе
- недостајући geo/device подаци морају бити означени као ункновн
- ескалација не сме излагати непотребне податке аналитичару без обухвата

Могућа проширења

- адаптиве тхресхолд
- линк ка инцидент триаге-у
- фалсе-позитиве феедбацк

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-26. Девице куарантине и аццесс рестрицтион развојни ток

Оперативно ограничавање приступа уређају или крајња тачка-у када постуре или инцидент сигнал указује на ризик.

Табела 62. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	QuarantineCase, AccessRestriction, DevicePosture, ReleaseDecision, RestrictionScope
Предуслови	P1-26, P2-14, P2-08

Обавезни случајеви употребе

- отварање куарантине случаја
- примена симулиране аццесс рестрицтион одлуке
- обавештавање овнер-а уређаја
- верификација побољшања постуре-а
- релеасе из куарантине стања
- аудит одлуке и обухвата ограничења

Кључна безбедносна правила

- куарантине мора имати разлог, обухват и рок или услов изласка
- релеасе мора имати доказ или одобрење
- ограничење не сме блокирати шири обухват од дефинисаног без одлуке
- непознат уређај не сме аутоматски добити трустед статус

Могућа проширења

- МДМ адаптер симулатор
- темпорари ексцептион
- куарантине дасхбоард

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-27. Евиденце цоллецтион пацкаге и хандофф развојни ток

Креирање контролисаног евиденце пакета за инцидент, аудит или контролу, укључујући минималне доказе и цхаин-оф-цустоди.

Табела 63. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	EvidencePackage, Хандофф, EvidenceManifest, IntegrityCheck, RecipientScope
Предуслови	P1-27, P2-10, P2-09

Обавезни случајеви употребе

- формирање евиденце пакета
- избор релевантних евиденце итем-а
- генерисање манифеста и интегрити метадата
- контролисана предаја овлашћеном примаоцу
- евиденција приступа и преузимања
- верификација пакета након хандофф-а

Кључна безбедносна правила

- пакет не сме садржати доказе ван обухвата случаја
- сваки приступ пакету мора бити аудитован

- манифест мора омогућити проверу интегритета без излагања тајни
- хандофф мора имати примаоца, време и сврху

Могућа проширења

- експорт у архиву
- редацтион развојни ток
- легал-холд метадата као едукативно проширење

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-28. Инцидент плаибоок ексецутион трацкинг

Праћење извршења плаибоок корака током инцидента, са одговорностима, евиденце-ом и одступањима.

Табела 64. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	PlaybookRun, StepExecution, ManualApproval, Девиатион, StepEvidence
Предуслови	P1-28, P2-09, P2-10

Обавезни случајеви употребе

- покретање плаибоок-а над инцидентом
- додела корака одговорним улогама
- евиденција извршења или прескакања корака
- тражење ручног одобрења за осетљив корак
- прикупљање евиденце-а по кораку
- затварање плаибоок рун-а са одступањима

Кључна безбедносна правила

- прескочен корак мора имати разлог
- оштећујућа или привилегована акција мора имати аппровал или сафети цхецк
- плаибоок рун користи верзију плаибоок-а важећу у тренутку покретања
- аутоматски корак не сме извршити реалну деструктивну акцију у студентском окружењу

Могућа проширења

- СЛА по кораку
- рунбоок тимелине
- пост-инцидент импровемент задатак

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-29. Цровн-јевел аццесс надзор

Праћење приступа критичним ассет-има и подацима, са посебним правилима за детекцију и аудит.

Табела 65. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CriticalAccessEvent, CrownJewelPolicy, AccessPattern, MonitoringRule, OwnerNotification

Елемент	Спецификација
Предуслови	P1-29, P1-06, P2-17

Обавезни случајеви употребе

- идентификација приступа цровн-јевел ресурсу
- примена посебних надзор правила
- генерисање догађаја за неуобичајен приступ
- обавештавање овнер-а када политика то захтева
- преглед историје приступа по ресурсу
- повезивање догађаја са incident/risk ставком

Кључна безбедносна правила

- критичан ресурс мора имати јасну политику мониторинга или евидентиран гап
- надзор не сме чувати непотребни садржај података
- овнер нотификатион мора поштовати обухват и класификацију
- приступ дозвољеном кориснику и даље може бити аудитован без аутоматске оптужбе

Могућа проширења

- бехавиор баселине
- овнер аттестатион
- хигх-валуе ассет дасхбоард

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P2-30. Цонтрол аттестатион и овнер фоллов-уп

Оперативно прикупљање изјава овнер-а о статусу контрола и праћење недостајућих или негативних одговора.

Табела 66. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ControlAttestation, OwnerResponse, FollowUpAction, AttestationPeriod, ControlStatus
Предуслови	P1-30, P3-07, P1-09

Обавезни случајеви употребе

- покретање аттестатион периода
- слање захтева овнер-у контроле
- евиденција потврде или изузетка
- ескалација неодговорених захтева
- повезивање одговора са евиденце-ом
- затварање периода са гап извештајем

Кључна безбедносна правила

- аттестатион мора референцирати контролу, овнер-а и период
- потврда без евиденце-а мора бити означена као селф-аттестед
- неодговорен захтев не сме се третирати као позитивна потврда
- промена овнер-а током периода мора бити следљива

Могућа проширења

- цампаигн темплатес
- риск-басед самплинг
- дасхбоард овнер цовераге

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

9 Пројектне целине нивоа P3

Целине P3 уводе policy/risk оркестрацију, сложеније одлуке, цоррелатион и аутоматизовану реакцију.

P3-01. Полици енгине и атрибутска ауторизација

Доношење одлуке о приступу на основу комбинације идентитета, ресурса, контекста и политике.

Табела 67. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	PolicyDecision, SubjectAttribute, ResourceAttribute, EnvironmentContext, DecisionReason
Предуслови	P1-06, P1-07, P1-08

Обавезни случајеви употребе

- евалуација политике
- комбиновање атрибута
- објашњење allow/deny разлога
- верзионисање полици сета
- тестирање полици сценарија

Кључна безбедносна правила

- полици енгине мора имати детерминистичке резултате за исти контекст
- дени-би-дефаулт мора бити експлицитна одлука где је примењена
- nejasan/konfliktan полици мора имати дефинисано правило приоритета

Могућа проширења

- АБАЦ
- риск-аваре полици
- полици симулатион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-02. Периодиц аццесс преглед и цертификатион

Периодична провера да ли корисници и сервиси и даље треба да имају додељена права.

Табела 68. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AccessReview, ReviewItem, Ревиевер, CertificationDecision, ReviewPeriod
Предуслови	P1-05, P2-03, P2-04

Обавезни случајеви употребе

- креирање преглед кампање
- генерисање ставки
- potvrda/ukidanje права
- праћење преглед статуса
- затварање кампање

Кључна безбедносна правила

- преглед не сме аутоматски потврдити приступ због неактивности ревиевера
- привилегована права имају строжи преглед
- одлука мора бити аудитована

Могућа проширења

- манагер преглед
- овнер преглед
- цонтинуоус цертификатион

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-03. Риск регистер и процена безбедносног ризика

Повезивање ассет-а, претње, слабости и контрола у структурисан риск модел.

Табела 69. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Риск, Тхреат, Веакнесс, Импацт, Ликелихоод, ResidualRisk
Предуслови	P1-02, P2-11

Обавезни случајеви употребе

- креирање ризика
- процена impact/likelihood
- повезивање контроле
- израчун резидуалног ризика
- prihvatanje/mitigacija

Кључна безбедносна правила

- риск сцоре није замена за образложење
- промена ассет критичности мора покренути ревизију релевантног ризика
- риск аццептанце захтева овнер-а и период прегледа

Могућа проширења

- риск матрикс
- треатмент план
- риск аппетите

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-04. Моделовање претњи развојни ток

Систематско евидентирање труст граница, претњи и планираних контрола за апликационе целине.

Табела 70. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ThreatModel, TrustBoundary, DataFlow, Тхреат, Митигатион
Предуслови	P1-02, P3-03

Обавезни случајеви употребе

- креирање тхреат модел-а
- евиденција труст границе
- повезивање претње са asset-om/tokom
- додела митигације
- преглед модела након промене

Кључна безбедносна правила

- тхреат модел мора бити везан за конкретан sistem/tok
- митигација мора имати проверљив захтев
- модел се ревидира након значајне архитектонске промене

Могућа проширења

- СТРИДЕ-лике цатегори метадата
- диаграм аттацхмент
- цханге-триггеред преглед

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-05. Сецурити евент цоррелатион и аналитицс

Комбиновање више догађаја у објашњиву безбедносну слику без обавезног МЛ-а.

Табела 71. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CorrelationRule, EventWindow, EntityKey, CorrelationResult, Цонфиденце
Предуслови	P1-09, P2-07

Обавезни случајеви употребе

- корелација више евент типова
- груписање по identitetu/asset-u
- временски прозор
- израчун објашњивог цонфиденце-а
- ескалација у алерт

Кључна безбедносна правила

- цоррелатион правило мора бити тестабилно и објашњиво
- недостајући догађај се не измишља

- цонфиденце није доказ инцидента

Могућа проширења

- session/entity грапх
- бехавиор баселине
- симпле аномали сцоре

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-06. Аутоматизација цонтаинмент и респонсе акција

Контролисана примена безбедносних акција одговора уз заштиту од погрешне аутоматизације.

Табела 72. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ResponseAction, Плаибоок, ApprovalMode, ActionOutcome, RollbackRef
Предуслови	P2-02, P2-09, P2-05

Обавезни случајеви употребе

- предлог цонтаинмент акције
- ručno/automatsko одобрење
- укидање сесије
- привремена суспензија идентитета
- ревоке цредентиал-а
- евиденција исхода

Кључна безбедносна правила

- деструктивна или широка акција захтева виши ниво одобрења
- аутоматизација мора бити идемпотентна где је могуће
- респонсе акција мора оставити аудит траг и могућност роллбацк-а када је релевантно

Могућа проширења

- плаибоок енгине
- аппровал тиерс
- сафе дри-рун

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-07. Цомплианце евиденце и цонтрол маппинг

Повезивање безбедносних контрола са техничким доказима и периодима важења.

Табела 73. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	Цонтрол, Рекуиремент, EvidenceRef, Ассессмент, ComplianceStatus
Предуслови	P1-08, P1-09

Обавезни случајеви употребе

- дефинисање контроле
- повезивање са полици-ем
- додавање доказа
- процена стања
- периодични преглед

Кључна безбедносна правила

- цомплианце статус није исто што и одсуство ризика
- доказ мора имати извор и период важења
- истекао доказ не сматра се аутоматски важећим

Могућа проширења

- цонтрол фрамеворк маппинг
- евиденце аутоматион
- ассессмент цампаигн

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-08. Сецурити ексцептионс и риск аццептанце

Формално управљање одступањима од политика или баселине-а уз власника, рок и ризик.

Табела 74. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityException, PolicyRef, RiskRef, Овнер, ExpiresAt
Предуслови	P1-08, P1-10, P3-03

Обавезни случајеви употребе

- подношење изузетка
- odobravanje/odbijanje
- повезивање са ризиком
- истек изузетка
- обнова уз нову процену

Кључна безбедносна правила

- изузетак не брише основну политику
- сваки изузетак има рок
- истекао изузетак враћа статус у неусаглашено стање ако проблем остаје

Могућа проширења

- темпорари цомпенсатинг цонтрол
- ексцептион СЛА
- булк преглед

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-09. Пост-инцидент преглед и сецурити импровемент трацкинг

Претварање искуства из инцидента у мерљиве корективне и превентивне акције.

Табела 75. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	PostIncidentReview, Финдинг, ActionItem, Овнер, DueDate
Предуслови	P2-09, P2-10

Обавезни случајеви употребе

- покретање преглед-а
- евиденција роот цаусе-а на одговарајућем нивоу
- дефинисање акција
- праћење реализације
- затварање уз верификацију

Кључна безбедносна правила

- ПИР није место за приписивање кривице појединцу
- акција мора имати овнер-а и рок
- инцидент се може затворити оперативно пре завршетка свих импровемент акција, али оне остају следљиве

Могућа проширења

- тренд финдингс
- рецуррент инцидент линк
- контрол ефффективенесс преглед

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-10. Аттацк-патх и експосуре грапх анализа

Дефанзивна анализа могућих путева од улазне тачке до критичног ассет-а на основу познатих труст, вулнерабилити и привилеге веза, без извођења реалног напада.

Табела 76. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AttackPath, ExposureEdge, EntryPoint, PrivilegeStep, CriticalAsset, Митигатион
Предуслови	P1-02, P1-14, P2-11, P3-04

Обавезни случајеви употребе

- изградња експосуре графа из ассет, труст-боундари и вулнерабилити података
- проналажење могућих путева ка критичном ассет-у
- рангирање пута према броју корака, критичности и познатим слабостима
- вхат-иф уклањање вулнерабилити или труст везе ради процене митигације
- додела власника и ремедиатион акције за високоризичан пут
- периодично поновно израчунавање након промене инвентара

Кључна безбедносна правила

- аттацк-патх је аналитички модел и не сме аутоматски доказивати да је експлоит могућ
- критичност и цонфиденце улазних података морају бити видљиви
- непозната веза не сме се имплицитно третирати као безбедна
- анализа се изводи искључиво над сопственим регистрима и симулаторима

Могућа проширења

- грапх centrality/risk хеуристика
- аттацк-патх преглед измена између две верзије система
- мапирање митигације на сецурити цонтролс

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-11. Тхирд-парти и супплиер сецурити ассессмент

Управљање безбедносним проценама добављача и екстерних сервиса који имају утицај на интерне ассет-е или податке.

Табела 77. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ThirdParty, SupplierService, Ассессмент, Финдинг, AssuranceEvidence, RiskDecision
Предуслови	P1-02, P1-16, P3-03

Обавезни случајеви употребе

- регистрација тхирд-парти организације и услуге
- повезивање добављача са интерним ассет-има и дата класама
- покретање периодичне сецурити процене
- евиденција налаза, доказа и рокова за одговор
- риск аццептанце или ремедиатион одлука за значајан налаз
- праћење истека ассессмент-а и потребе за поновном провером

Кључна безбедносна правила

- тхирд-парти ассессмент мора имати власника и датум важења
- добављачки доказ не сме аутоматски затворити интерни риск без преглед-а
- поверљиви документи се моделују метаподацима или безбедним тест артефактима
- критична услуга са истеклом проценом мора бити видљива као риск сигнал

Могућа проширења

- стандардизед куестионнаире темплате
- супплиер тиеринг
- contract/security облигатион трацкинг

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-12. Цонтинуоус цонтрол ефффецтивенесс и сецурити постуре

Аналитика која повезује контроле, тестове, догађаје и евиденце како би се проценила актуелност и ефективност безбедносних мера кроз време.

Табела 78. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ControlMetric, ControlTestResult, Цовераге, EffectivenessScore, EvidenceFreshness, PostureTrend
Предуслови	P1-16, P3-05, P3-07

Обавезни случајеви употребе

- пријем резултата контролних тестова или верификованих евиденце сигнала
- израчунавање цовераге-а по контроли и ассет обухват-у
- детекција застарелог или недостајућег доказа
- рачунање верзионисаног ефффецтивенесс сцоре-а са објашњивим факторима
- тренд преглед poboljšanja/pogoršanja постуре-а
- дрилл-довн са агрегата до конкретног фаилед теста или евиденце записа

Кључна безбедносна правила

- миссинг евиденце не сме бити третиран као пасс
- сцоре формула мора бити документована, верзионисана и репродуктибилна
- агрегатни сцоре не сме сакрити отворен критичан налаз
- аналитицс компонента не мења аутоматски риск аццептанце или инцидент одлуку

Могућа проширења

- цонтрол хеат-мап
- СЛА за евиденце фресхнесс
- вхат-иф постуре након планиране митигације

Доказ завршетка. Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове, документовану границу поверења према другим целинама и најмање један репрезентативан негативни или абусе-цасе сценарио.

P3-13. Сегрегатион оф дутиес и токсиц-аццесс анализа

Анализа комбинација улога, привилегија и власништва ради детекције недозвољених или ризичних концентрација овлашћења.

Табела 79. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SodRule, ToxicCombination, EntitlementSet, ConflictFinding, Митигатион, CompensatingControl
Предуслови	P1-05, P1-06, P2-03, P3-02

Обавезни случајеви употребе

- дефинисање СоД правила и забрањених комбинација
- израчунавање ефективних привилегија корисника
- детекција токсиц цомбинатион налаза
- процена утицаја привременог ЈИТ гранта на СоД

- предлагање уклањања привилегије или цомпенсатинг контроле
- одобравање временски ограниченог изузетка
- периодична реевалуација након промене улога

Кључна пословна правила

- налаз мора бити заснован на ефективним, не само директно додељеним привилегијама
- ЈИТ привилегија се укључује у анализу током периода важења
- изузетак мора имати власника, разлог и рок
- систем не сме аутоматски укидати приступ без дефинисаног аппровал процеса
- правило и резултат морају бити репродуковљиви уз верзију полици-ја

Могућа проширења

- граф ентитлемент зависности
- роле мининг препоруке
- хигх-риск цомбинатион дасхбоард

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-14. Риск-басед адаптиве аутхентицатион

Динамичка одлука о потребном нивоу аутентикације на основу контекста пријаве и верзионисане риск политике.

Табела 80. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AuthenticationRisk, ContextSignal, RiskPolicy, StepUpDecision, TrustedContext, RiskOutcome
Предуслови	P2-01, P2-02, P2-14, P1-08

Обавезни случајеви употребе

- прикупљање дозвољених контекстуалних сигнала из симулираног логин захтева
- израчунавање риск сцоре-а према објашњивој политици
- дозвола стандардне аутентикације за низак ризик
- захтев за степ-уп фактор при повећаном ризику
- блокада или додатна провера високоризичног покушаја
- евиденција одлуке и релевантних сигнала без непотребног чувања осетљивих података
- накнадна анализа false-positive/false-negative сценарија

Кључна пословна правила

- одлука мора бити детерминистичка или репродуковљива за исти цонтекст снапсхот
- осетљиви сигнали се минимизују и чувају само колико је потребно
- риск сцоре не замењује сервер-сиде аутхоризатион
- недостајући сигнал не сме аутоматски значити низак ризик
- промена риск политике не мења историјску одлуку

Могућа проширења

- гео-велоцити симулатор
- трустед девице веигхтинг
- усер нотификатион за ризичну пријаву

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-15. Детецтион енгинееринг, симулација и тунинг правила

Животни циклус детецтион правила од предлога преко симулације на контролисаним догађајима до мерења квалитета и продукционог одобрења.

Табела 81. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	DetectionRuleVersion, TestCorpus, DetectionRun, TruePositive, FalsePositive, Цовераге, TuningDecision
Предуслови	P2-07, P2-17, P1-12

Обавезни случајеви употребе

- креирање нове верзије детецтион правила
- дефинисање контролисаног тест цорпус-а симулираних догађаја
- извршавање правила над цорпус-ом
- израчунавање основних куалити метрика
- поређење две верзије правила
- odobravanje/promocija izabrane verzije
- евиденција тунинг одлуке и разлога

Кључна пословна правила

- тест цорпус не сме садржати стварне тајне или туђе осетљиве податке
- промена руле верзије мора бити следљива
- куалити метрика мора имати јасно дефинисан скуп очекиваних резултата
- правило са лошијим резултатом не сме аутоматски заменити активну верзију без експлицитне одлуке
- симулација не сме креирати стварне цонтаинмент акције

Могућа проширења

- цовераге по АТТ&ЦК-лике категорији без обавезног спољног феед-а
- схадов евалуатион
- регрессион суите за детецтион рулес

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-16. Дата-аццесс аномали и ексфилтратион риск аналитика

Анализа безбедносних метаподатака о приступу класификованим подацима ради препознавања неуобичајених образаца без потребе за чувањем самог садржаја.

Табела 82. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AccessPattern, Баселине, AnomalySignal, ExfiltrationRisk, PeerGroup, InvestigationCandidate
Предуслови	P1-07, P2-15, P2-17, P3-05

Обавезни случајеви употребе

- агрегација аццесс метадата по кориснику, ресурсу и периоду
- изградња једноставног објашњивог баселине-а
- детекција неуобичајеног обима или дестинатион обрасца
- комбиновање са класификацијом података и труст зоном
- генерисање инвестигатион кандидата са разлозима
- suppress/close одлука уз образложење
- периодична реевалуација баселине-а без ретроактивног мењања налаза

Кључна пословна правила

- аномалија није доказ инцидента и мора бити означена као сигнал
- аналитика користи минимизоване метадата податке, не пуни садржај
- баселине мора чувати период и верзију методе
- нов корисник или недовољно података мора имати експлицитан цолд-старт исход
- tenant/security-domain обухват мора бити поштован

Могућа проширења

- пеер-гроуп поређење
- сеасоналити по радном времену
- риск сцоре са ДЛП догађајима

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-17. Софтваре провенанце и релеасе труст верификација

Процена поверења у софтверски релеасе на основу депенденци инвентара, изградња провенанце метадата, аппровал-а и познатих сецурити налаза.

Табела 83. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ReleaseArtifact, ProvenanceAttestation, BuildIdentity, DependencySnapshot, TrustPolicy, ReleaseDecision
Предуслови	P2-13, P2-11, P1-16

Обавезни случајеви употребе

- регистрација релеасе артефакта и изградња провенанце метадата
- повезивање релеасе-а са dependency/SBOM снапсхот-ом
- провера обавезних build/approval доказа према труст полици-ју
- евалуација познатих критичних вулнерабилити налаза у депенденци-јима
- доношење allow/warn/block релеасе одлуке
- одобравање контролисаног изузетка уз рок
- поновна евалуација након појаве новог депенденци налаза

Кључна пословна правила

- одсуство провенанце доказа не сме бити представљено као потврђена безбедност
- труст одлука мора референцирати верзију полици-ја и депенденци снапсхот
- изузетак не уклања изворни финдинг
- релеасе одлука не сме зависити од мутабле тага без стабилног digest/identiteta
- приступ детаљима изградња система мора поштовати обухват

Могућа проширења

- сигнед аттестатион метадата
- релеасе промотион гате
- провенанце цхаин висуализатион

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-18. Приваци импацт и дата-процессинг ассессмент

Структурисана процена ризика обраде личних или посебно осетљивих података на основу дата-флов регистра, сврхе, класификације и контрола.

Табела 84. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ProcessingActivity, PrivacyRisk, Пурпосе, DataSubjectCategory, Митигатион, AssessmentVersion
Предуслови	P1-07, P1-20, P3-03, P1-16

Обавезни случајеви употребе

- регистрација процессинг активности и пословне сврхе
- идентификација категорија података и токова који учествују
- процена privacy/security ризика према дефинисаној методологији
- повезивање постојећих контрола и гап-ова
- дефинисање митигатион активности и власника
- одобравање процене и периодичне реевалуације
- отварање нове верзије процене након значајне промене дата флов-а

Кључна пословна правила

- процена мора чувати верзију методологије и улазни обухват
- сврха обраде мора бити експлицитна и не може бити накнадно тихо проширена
- ассессмент не сме садржати стварне личне податке када нису потребни
- непознат ток осетљивих података мора бити евидентиран као гап
- затворена процена остаје историјски следљива

Могућа проширења

- приваци цонтрол маппинг
- дата минимизатион цхецклист
- ассессмент преглед измена између верзија

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-19. Цриптографхиц постуре и мигратион планнинг

Аналитички преглед криптографске изложености организације и планирање преласка са застарелих алгоритама, кључева или сертификационих профила.

Табела 85. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	CryptoPosture, AlgorithmRisk, ExpiryForecast, MigrationWave, DependencyImpact, CryptoDebt
Предуслови	P1-17, P2-19, P3-10

Обавезни случајеви употребе

- агрегација црипто ассет-а по алгоритму, старости и критичности
- детекција застарелих или ускоро неважећих профила
- импацт анализа сервиса зависних од одређеног algoritma/credential типа
- груписање миграције у контролисане таласе
- процена приоритета према критичности и експосуре-у
- праћење напретка мигратион плана
- рецалцулација постуре-а након завршене ротације

Кључна пословна правила

- постуре сцоре мора имати документовану формулу
- непознат алгоритам или метадата мора бити означен као гап
- мигратион план не сме аутоматски ротирати продукционе цредентиал-е
- историјска процена мора остати репродуктибилна
- приоритет мора узети у обзир и пословни импацт, не само техничку застарелост

Могућа проширења

- црипто-агилити дасхбоард
- вхат-иф депрецатион сценарио
- експири цонцентратион хеатмап

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-20. Сецурити метрицс, риск куантификатион и ексецутиве постуре

Конзистентан скуп безбедносних KPI/KRI показатеља који повезује ризике, инциденте, контролне налазе и ремедиатион трендове без стварања лажне прецизности.

Табела 86. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	SecurityMetric, КРИ, КПИ, RiskTrend, MetricSnapshot, Цонфиденце, PostureReport
Предуслови	P3-03, P3-05, P3-07, P3-12

Обавезни случајеви употребе

- дефинисање метрике са формулом, изворима и овнер-ом
- периодични снапсхот безбедносних KPI/KRI вредности
- тренд отворених хигх-риск налаза и ремедиатион времена
- агрегација цонтрол ефффективенесс и инцидент података
- приказ confidence/data-quality ознаке уз метрику
- генерисање ексецутиве постуре извештаја са дрилл-довн изворима
- верзионисање дефиниције метрике без измене историјских снапсхот-а

Кључна пословна правила

- свака метрика мора имати јасно дефинисану формулу и извор
- недостајући подаци не смеју се аутоматски третирати као нула
- агрегирани сцоре мора приказати ограничења и цонфиденце
- историјски снапсхот користи дефиницију која је важила тада
- извештај мора поштовати сецурити-домаин и роле обухват

Могућа проширења

- веигхтед риск хеатмап
- target/threshold трацкинг
- тренд форецастинг једноставном објашњивом методом

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-21. Дата-субјецт рекуест и приваци ригхтс развојни ток

Координација захтева субјекта података кроз дата-флов, цонсент и евиденце евиденције без правног сертификовања система.

Табела 87. Елемен̄т и Сп̄ецификација

Елемент	Спецификација
Кључни појмови	DataSubjectRequest, RequestType, VerificationStatus, FulfillmentTask, ResponsePackage
Предуслови	P1-21, P1-20, P2-18

Обавезни случајеви употребе

- отварање дата-субјецт захтева
- верификација идентитета кроз контролисан статус
- проналажење релевантних токова и складишта података
- креирање фулфиллмент задатака по систему
- генерисање минималног респонсе пакета
- затварање захтева уз аудит

Кључна безбедносна правила

- захтев не сме бити обрађен без верификације идентитета или одговарајућег статуса
- респонсе пакет мора поштовати класификацију и обухват
- brisanje/izmena података не сме бити симулирана као правна гаранција без обележавања ограничења
- сваки корак мора бити аудитабилан

Могућа проширења

- СЛА трацкинг
- редацтион превиев
- партиал фулфиллмент реасон

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-22. Хуман-риск аналитицс и таргетед аваренесс планнинг

Аналитика хуман-риск сигнала из тренинга, инцидената и полици налаза ради планирања циљане едукације без профилисања ван домета пројекта.

Табела 88. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	HumanRiskSignal, AwarenessPlan, TargetGroup, RiskFactor, Рецоммендатион
Предуслови	P1-22, P2-22, P3-05

Обавезни случајеви употребе

- агрегација аваренесс и инцидент сигнала
- формирање објашњивих риск фактора по групи
- предлог циљане обуке или кампање
- поређење трендова пре и после кампање
- ручна потврда плана
- чување образложења препоруке

Кључна безбедносна правила

- аналитика се користи на групном или контролисаном обухват-у, не за неосновано етикетирање појединца
- препорука мора бити објашњива
- недостајући подаци морају бити означени као ограничење
- план не сме аутоматски слати кампању без одобрења

Могућа проширења

- теам-левел хеатмап
- рецоммендатион цонфиденце
- аваренесс ефффективенесс тренд

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-23. Ексцептион портфолио риск аналитицс

Анализа портфолија сецурити изузетака, концентрације ризика, истека и цомпенсатинг цонтрол квалитета.

Табела 89. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ExceptionPortfolio, RiskConcentration, ExpiryCluster, CompensatingControlQuality, PortfolioTrend
Предуслови	P1-23, P2-23, P3-03

Обавезни случајеви употребе

- агрегација активних изузетака
- идентификација концентрације по ассет-у, контроли или овнер-у
- детекција изузетака близу истека
- процена квалитета цомпенсатинг цонтрол-а
- рангирање изузетака за преглед
- генерисање портфолио извештаја

Кључна безбедносна правила

- агрегирани сцоре мора приказати формулу и ограничења
- истекли изузетак мора бити посебно означен, не тихо рачунат као важећи
- риск анализа не сме аутоматски одобрити или укинути изузетак
- недостајући подаци умањују цонфиденце

Могућа проширења

- ексцептион дебт тренд
- преглед приоритизатион
- цонтрол гап мапа

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-24. Нон-хуман идентити постуре аналитицс

Аналитика ризика сервице аццоунт-а и мацхине идентити-ја кроз обухват, ротацију, власништво и активност.

Табела 90. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	NhiPosture, ServiceAccountRisk, CredentialAge, ScopeBreadth, OwnerCoverage
Предуслови	P1-24, P2-24, P3-12

Обавезни случајеви употребе

- агрегација нон-хуман идентити записа
- израчунавање риск фактора
- детекција старих цредентиал-а и орпхан налога
- поређење постуре-а кроз време
- генерисање препорука за review/cleanup
- чување снапсхот-а постуре-а

Кључна безбедносна правила

- риск сцоре мора бити објашњив кроз факторе
- нема аутоматског укидања идентитета без развојни ток-а
- непозната активност или овнер мора бити означена као rizik/gap
- снапсхот користи правила која су важила тада

Могућа проширења

- идентити грапх
- ротатион план симулатор
- привилеге бреадтх сцоре

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-25. Идентити тхреат хунтинг нотебоок

Контролисано окружење за објашњиве упите и хипотезе над identity/security догађајима, без реалног напада и без излагања тајни.

Табела 91. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	HuntingQuery, Хипотхесис, Финдинг, EvidenceLink, QueryVersion
Предуслови	P2-17, P2-25, P3-05

Обавезни случајеви употребе

- креирање хунтинг хипотезе
- дефинисање упита над нормализованим догађајима
- чување резултата као финдинг-а
- повезивање финдинг-а са evidence/incident записом
- верзионисање упита
- означавање фалсе-позитиве исхода

Кључна безбедносна правила

- хунтинг упит не сме приказати тајне или непотребни садржај
- финдинг је хипотеза док се не потврди
- иста верзија упита над истим подацима мора дати репродуктибилан резултат
- приступ нотебоок-у мора поштовати role/scope

Могућа проширења

- куери либрари
- сцхедулед хунт симулатор
- маппинг на МИТРЕ технику

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-26. Зеро-труст реадинесс и матурити ассессмент

Процена зрелости идентитета, уређаја, труст граница и полици енфорцемент-а кроз контролисан модел зрелости.

Табела 92. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	ZeroTrustCapability, MaturityLevel, Гап, ImprovementPlan, AssessmentSnapshot
Предуслови	P1-14, P2-14, P3-12

Обавезни случајеви употребе

- дефинисање цапабилити модела
- прикупљање евиденце-а за зрелост
- додела матурити нивоа по области
- идентификација гап-ова
- формирање импровемент плана
- чување ассессмент снапсхот-а

Кључна безбедносна правила

- матурити ниво мора имати критеријуме и евиденце
- недостајући евиденце не сме се третирати као испуњење

- ассессмент је интерни едукативни модел, не формална сертификација
- промена критеријума не сме ретроактивно мењати старе снапсхот-е

Могућа проширења

- радар цхарт
- таргет матурити планнинг
- бенцхмарк симулатор без реалних тврдњи

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-27. Евиденце куалити сцоринг и аудит реадинесс

Процена квалитета доказа и спремности за интерну проверу кроз цовераге, интегритет, цхаин-оф-цустоди и класификацију.

Табела 93. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	EvidenceQualityScore, CoverageGap, IntegritySignal, AuditReadiness, EvidenceDefect
Предуслови	P1-27, P3-07, P2-27

Обавезни случајеви употребе

- евалуација евиденце пакета
- детекција недостајућих доказа по контроли
- провера интегрити и цхаин-оф-цустоди сигнала
- израчунавање објашњивог куалити сцоре-а
- генерисање гап листе
- праћење побољшања реадинесс-а

Кључна безбедносна правила

- сцоре мора навести факторе и ограничења
- недостајући доказ не сме бити третиран као позитиван резултат
- аудит реадинесс није формална сертификација
- само корисници са обухват-ом могу видети детаље доказа

Могућа проширења

- евиденце линтинг
- реадинесс дасхбоард
- цонтрол-то-евиденце трацеабилити матрикс

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-28. Сецурити аутоматион говернанце

Управљање аутоматским сецурити акцијама кроз дозволе, сафети цхецкс, роллбацк и риск аццептанце пре извршења.

Табела 94. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AutomationPolicy, ActionScope, SafetyCheck, RollbackPlan, AutomationDecision

Елемент	Спецификација
Предуслови	P1-28, P3-06, P3-08

Обавезни случајеви употребе

- регистрација аутоматизоване сецурити акције
- дефинисање обухвата и сафети цхецк-а
- процена ризика пре активације
- ручно одобрење за осетљиве акције
- евиденција извршења и роллбацк плана
- преглед аутоматизације након инцидента

Кључна безбедносна правила

- аутоматизација не сме извршити деструктивну акцију без обухвата и сафети цхецк-а
- свака акција мора бити аудитована
- роллбацк план мора постојати за акције које мењају стање
- отказ аутоматизације не сме сакрити стварни инцидент статус

Могућа проширења

- симулатион моде
- аппровал полици енгине
- аутоматион бласт-радиус естимате

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-29. Цровн-јевел риск сценарио аналисис

Анализа сценарија ризика над најкритичнијим ассет-има кроз тхреат, експосуре, контролу и бусинесс импацт.

Табела 95. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	RiskScenario, CrownJewelAsset, ThreatPath, ControlGap, ScenarioImpact
Предуслови	P1-29, P3-03, P3-10

Обавезни случајеви употребе

- избор цровн-јевел ассет-а
- формирање threat/risk сценарија
- повезивање експосуре и контролних гап-ова
- процена импацт-а и вероватноће као едукативног модела
- поређење митигационих опција
- чување сценарио снапсхот-а

Кључна безбедносна правила

- сценарио мора разликовати претпоставке од чињеница
- риск сцоре мора бити објашњив и не сме стварати лажну прецизност
- митигација не сме аутоматски мењати контроле без развојни ток-а
- недостајући dependency/exposure подаци морају бити означени

Могућа проширења

- вхат-иф митигатион
- ексецутиве сценарио бриеф
- сценарио либрари

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

P3-30. Цонтрол ассуранце роадмап и гап планнинг

Планирање побољшања контрола кроз гап анализу, овнер-е, приоритете и зависности, без мењања оцењивања пројекта.

Табела 96. Елемент и Спецификација

Елемент	Спецификација
Кључни појмови	AssuranceRoadmap, ControlGap, ImprovementInitiative, Депенденци, TargetState
Предуслови	P1-30, P3-12, P3-20

Обавезни случајеви употребе

- агрегација контролних гап-ова
- дефинисање таргет стате-а
- приоритизација импровемент иницијатива
- повезивање зависности и овнер-а
- формирање роадмап-а
- праћење статуса и доказа завршетка

Кључна безбедносна правила

- роадмап ставка мора имати овнер-а, разлог и очекивани доказ
- приоритет мора бити објашњив кроз risk/impact/effort факторе
- план не сме приказивати гап као решен без евиденце-а
- промена циља мора остати аудитабилна

Могућа проширења

- куартерли роадмап виев
- депенденци графх
- риск редуцтион естимате

Доказ завршетка: Целина мора имати извршиве кључне случајеве употребе, аутоматизоване тестове пословних правила, документовану јавну границу према другим целинама и најмање један репрезентативан демо сценарио.

10 Интеграција, безбедносно тестирање и критеријуми завршетка

10.1 Препоручени интеграциони сценарији

Табела 97. Сценарио и Укључене области

Сценарио	Укључене области	Очекивани резултат
Хоризонтални приступ туђем ресурсу	Идентити + Контрола приступа заснована на улогама + Објецт Аутхоризатион + Аудит	403/deny без цурења података, уз одговарајући аудит догађај

Сценарио	Укључене области	Очекивани резултат
Привилегована промена улоге	Привилегед Аццесс + Степ-уп + Контрола приступа заснована на улогама + Нотификатион	промена се извршава само уз активан грант и додатну потврду
Ревокед сессион	Сессион + Аутхоризатион + Аудит	раније валидна сесија више не даје приступ
Ротација сервице цредентиал-а	Сервице Идентити + Сецретс + Апплицатион Симулатор	нова верзија постаје активна без излагања тајне
Сумњив образац пријава	Аутхентицатион + Евентс + Детецтион + Алерт	догађаји производе објашњив алерт без аутоматског инцидента ако полици то не тражи
Инцидент и цонтаинмент	Алерт + Инцидент + Респонсе + Session/Secret Ревоке	цонтаинмент акција је аудитована и ограничена дефинисаним обухват-ом
Вулнерабилити + риск	Ассет + Вулнерабилити + Риск + Ексцептион	налаз се повезује са пословним ризиком и има remediation/acceptance одлуку
Унманаged уређај тражи приступ	Идентити + Вишефакторска аутентикација + Девице Постуре + Полици	приступ добија детерминистички исход уз аудит без имплицитног поверења уређају
ДЛП покушај ка спољној зони	Дата Цлассификатион + Труст Зоне + ДЛП + Аудит	трансфер се dozvoljava/blokira према верзионисаној политици без чувања пуног садржаја
Аттацк-патх митигатион	Ассет + Труст Боундари + Вулнерабилити + Тхреат + Цонтрол	уклањање једне slabosti/veze мења аналитички пут и оставља проверљив траг одлуке
Црипто ротација критичног сервиса	Црипто Инвентори + Secrets/Certificates + Ротатион + Аудит	нова верзија се уводи контролисано, стара се повлачи тек након верификације и не излаже тајни материјал
Неочекиван интернет експосуре	Ассет + Аттацк Сурфаце + Вулнерабилити + Риск	непознати експосуре добија власника, процену и remediation/exception одлуку
Ризичан трансфер класификованих података	Дата Флов + Цлассификатион + Трансфер Аппровал + ДЛП	трансфер добија детерминистичку allow/deny одлуку уз минималан аудит метадата
Релеасе без довољно провенанце доказа	Суппли Цхаин + Провенанце + Вулнерабилити + Ексцептион	релеасе полици даје warn/block или контролисан ексцептион са роком и власником

10.2 Минимални тестни портфолио по тиму

Табела 98. Врста и Минимално очекивање

Врста	Минимално очекивање
Унит	полици, стате транзиције и безбедносна правила
Позитиве	дозвољени ток за овлашћеног субјекта
Негативе	недозвољени приступ или злоупотреба
Интегратион	authentication/authorization/secrets/audit граница
Регрессион	тест за стварно откривен проблем или високоризично понашање
Аудит евиденце	доказ да значајан сецурити догађај остаје следљив
Contract/security боундари	аццептед међутимски уговор, сецурити евент или полици формат има извршив тест компатибилности

Врста	Минимално очекивање
Операционал	цлеан цлоне, миграције и seed/demo сценарио раде поновљиво у документованом окружењу

10.3 Обавезни негативни сценарији

У зависности од целине, тим бира релевантан подскуп:

- корисник покушава приступ туђем објекту;
- корисник са погрешним обухват-ом покушава операцију;
- istekla/revoked сесија покушава приступ;
- привилегед грант је истекао;
- Вишефакторска аутентикација цхалленге је истекао или поновљен;
- ревокед certificate/credential се користи поново;
- сецурити евент је дуплиран;
- евиденце или аудит приступа корисник без дозволе;
- dependency/vulnerability налаз нема одговарајући ассет или овнер.

11 Предаја, документација и критеријуми оцењивања

11.1 Обавезна документација

- одговорност и труст граница пројектне целине;
- главни случајеви употребе и Тапиз аццептанце критеријуми;
- тхреат модел;
- јавни API/message уговори;
- Записи о архитектонским одлукама за значајне сецурити одлуке;
- упутство за локално покретање и тестирање;
- нормални и негативни демо сценарио;
- позната ограничења и ресидуал риск;
- списак јавних уговора, сецурити догађаја или полици граница са овнер-ом, цонсумер-има и лифецицле стањем;
- документоване миграције, seed/demo подаци и потребне конфигурационе променљиве без тајних вредности.

11.2 Оцењивање

Табела 99. Област и Шта се вреднује

Област	Шта се вреднује
Функционална исправност	обавезни случајеви употребе и стабилност
Безбедносни модел	идентитет, труст границе, леаст привилеге и тхреат модел
Ауторизација и заштита података	сервер-сиде одлуке, обухват, овнерсхип и класификација
Безбедносно тестирање	релевантни негативни и регрессион тестови
Аудитабилност	могућност доказивања значајне промене или сецурити исхода
Архитектура и дизајн	Clean/SOLID, јасне границе и контролисане зависности
Процес	Тапиз, Гит, ПР, преглед, Континуирана интеграција и континуитет рада
Интеграција	стабилни уговори и сарадња са другим тимовима
Одбрана	студент уме да објасни контролу, претњу, тест и ресидуал риск

Индивидуална одговорност. Сваки студент мора имати видљив допринос и бити способан да објасни најмање један безбедносни случај употребе, један негативни сценарио, релевантне тестове и труст границу своје целине.

11.3 Није прихватљиво

- сопствени алгоритам за пассворд хасхинг, енцриптион или дигитални потпис;
- хард-цодед цредентиалс и тајне;
- ауторизација само на УИ нивоу;
- крајња тачка-левел роле цхецк без object/scope провере када је она потребна;
- бесконачна или трајна привилегија без пословног разлога;
- аудит лог са лозинкама, токенима или сецрет вредностима;
- безбедносна контрола без негативног теста;
- симулација реалног напада над спољним системом;
- затварање vulnerability/risk ставке без доказа или формалног аццептанце-а.

12 Речник кључних појмова

Табела 100. Појам и Значење у оквиру ӣројекӣа

Појам	Значење у оквиру пројекта
Ассет	информациони ресурс који има власника, критичност и животни циклус
Идентити	људски или сервисни идентитет који учествује у безбедносној одлуци
Аутхентицатион	потврда идентитета
Аутхоризатион	одлука да ли субјект сме да изврши конкретну акцију над ресурсом
Контрола приступа заснована на улогама	ауторизација заснована на улогама и дозволама
Објецт-левел аутхоризатион	провера права над конкретним objektom/resursom
Степ-уп аутхентицатион	додатна потврда идентитета за осетљиву операцију
Привилегед Аццесс	повишени приступ који носи већи безбедносни ризик
Сецрет	осетљива вредност као Програмски интерфејс цредентиал, пассворд или кеи материал референца
Сервице Идентити	идентитет апликације или сервиса, одвојен од људског налога
Сецурити Евент	догађај релевантан за безбедносно праћење
Алерт	сигнал да је детецтион руле препознао услов за анализу
Сецурити Инцидент	потврђен или довољно значајан безбедносни проблем који захтева одговор
Евиденце	контролисано сачуван артефакт или запис релевантан за истрагу
Тхреат	потенцијални узрок нежељеног безбедносног исхода
Вулнерабилити / Веакнесс	слабост која може омогућити или повећати утицај претње
Риск	комбинација вероватноће, утицаја и контекста претње над ассет-ом
Сецурити Цонтрол	техничка или процесна мера која смањује ризик
Ресидуал Риск	ризик који остаје након примене контрола
Аудит	следљива евиденција значајне акције, субјекта и исхода
Труст Боундари	граница између зона различитог нивоа поверења преко које се ток мора експлицитно анализирати

Појам	Значење у оквиру пројекта
Ретентион Полици	верзионисано правило колико дуго се класа података чува и под којим условима уклања
Девице Постуре	скуп временски ограничених сигнала о безбедносном стању уређаја
ДЛП	контрола детекције и ограничавања недозвољеног кретања класификованих података
Аттацк Патх	аналитички низ могућих exposure/privilege корака ка циљном ассет-у, без доказа експлоита
Записи о архитектонским одлукама	кратак запис контекста, одлуке, алтернатива и последица архитектонске одлуке
Аттацк Сурфаце	скуп споља или међузонски доступних тачака кроз које систем може бити изложен безбедносном ризику
Провенанце	следљив метадата доказ о пореклу и процесу настанка софтверског артефакта
Сегрегатион оф Дутиес	правило раздвајања конфликтног скупа привилегија или одговорности између различитих субјеката
Цриптограпхиц Постуре	збирна процена стања криптографских средстава, алгоритама, истека и миграционих ризика
ConsentRecord	запис који повезује сврху обраде, субјект, статус цонсент-а и период важења
ServiceAccount	нон-хуман идентитет који користи сервис, радно оптерећење или аутоматизовани процес
EvidencePackage	контролисан скуп доказа са манифестом, интегритетом и цхаин-оф-цустоди метадата
Плаибоок	стандардизован скуп корака за безбедносни сценарио или инцидент, са одговорностима и доказима
CrownJewelAsset	критичан asset/podatak/proces чији компромис има висок пословни или безбедносни утицај
HumanRiskSignal	едукативни и агрегирани индикатор понашања, тренинга или налаза који захтева додатну пажњу; није етикета појединца
ZeroTrustCapability	област зрелости која процењује експлицитну проверу идентитета, уређаја, контекста и полици-ја
AutomationPolicy	правило које дефинише када и како је дозвољена аутоматизована сецурити акција